

PROJET ARCHITECTURE ZERO TRUST

Micro-segmentation et Sécurisation d'Infrastructure Virtualisée

Compte Rendu de Mise en Œuvre Intégral

1. Introduction Générale

Ce projet vise à démontrer comment une architecture **Zero Trust** combinée à la **micro-segmentation** permet de sécuriser un environnement on-premise virtualisé.

L'objectif est d'endiguer les mouvements latéraux et de protéger les ressources critiques (Base de données, Serveur d'Identité) contre des attaques internes ou des compromissions de périmètre. Le projet s'appuie sur une segmentation réseau stricte (VLANs), un pare-feu central (pfSense), une gestion centralisée des identités (FreeIPA) et une supervision en temps réel (Wazuh).

Ce compte rendu détaille étape par étape le déploiement de la solution de sécurité, en commençant par l'installation du cœur du réseau (pfSense) jusqu'à la configuration fine des règles de filtrage.

2. Architecture Globale du Système

2.1 Vue d'ensemble (Topologie GNS3)

L'architecture est organisée en zones fonctionnelles isolées par des VLANs. Le cœur du réseau est géré par pfSense qui agit comme routeur et pare-feu, filtrant tout trafic inter-VLAN. Cette centralisation des flux via le pare-feu est le prérequis fondamental pour appliquer une politique Zero Trust : aucun trafic ne circule directement entre les machines, tout passe obligatoirement par le point de contrôle central.

Le schéma ci-dessous présente la maquette déployée sous GNS3. On y distingue le routeur central (pfSense) connecté au "Switch1". Ce dernier dessert les différents nœuds du réseau : la machine cliente (zone Utilisateurs), les serveurs applicatifs (Web/BD), le serveur d'identité (FreeIPA) et la sonde de sécurité (Wazuh). Cette topologie en étoile garantit que tout le trafic transite par le pare-feu.

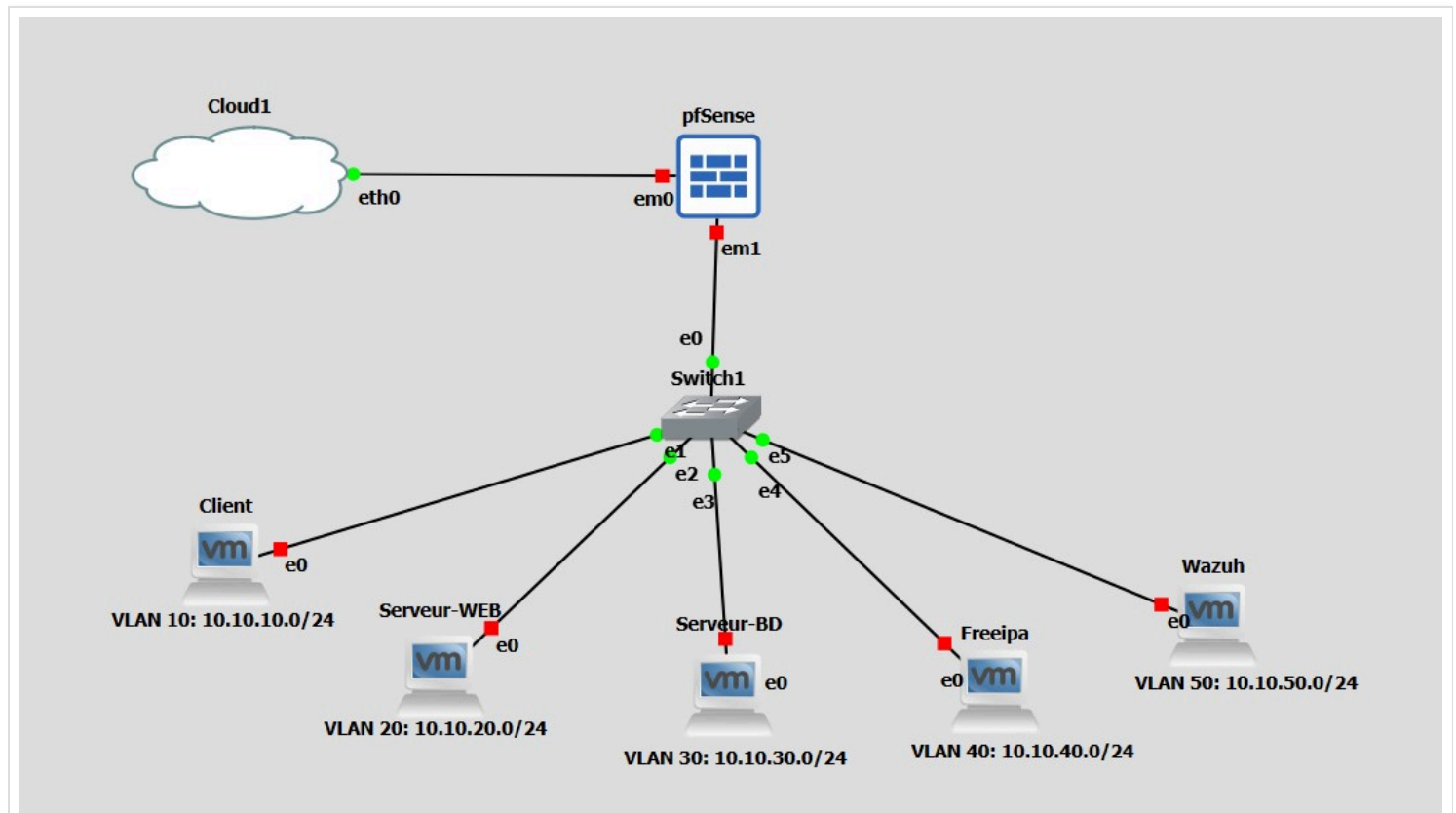


Figure 2.1 - Topologie globale du projet (GNS3).

On observe la topologie en étoile autour du commutateur. Le pfSense possède deux interfaces : WAN (accès externe) et LAN (vers le switch). C'est sur ce lien unique vers le switch que transiteront tous les VLANs (Trunking 802.1Q). Chaque machine virtuelle est connectée à un port spécifique du switch, assigné à un VLAN distinct.

3. Mise en place de la Segmentation Réseau (VLAN) et du Pare-feu

3.1 Configuration du Commutateur Virtuel (Niveau 2)

La segmentation commence au niveau de la couche liaison de données (L2). Pour que les VLANs soient étanches, le commutateur doit être correctement configuré avant même d'installer le pare-feu. Cette étape est critique car elle définit quels ports appartiennent à quel segment réseau.

Node properties

Switch1 configuration

General

Name: Switch1

Console type: none

Settings

Port: 8

VLAN: 1

Type: access

QinQ EtherType: 0x8100

Ports

Port	VLAN	Type	EtherType
0	1	dot1q	
1	10	access	
2	20	access	
3	30	access	
4	40	access	
5	50	access	
6	1	access	
7	1	access	

Buttons: Add, Delete, Reset, OK, Cancel, Apply

Figure 3.1 - Configuration des ports du Switch GNS3.

Le **Port 0** est configuré en mode **dot1q** (Trunk), ce qui lui permet de transporter tous les VLANs tagués (étiquetés) vers l'interface physique du pare-feu via un seul câble. Les autres ports (1 à 5) sont en mode **access**, assignant statiquement les machines connectées à leur VLAN respectif : Port 1 = VLAN 10 (Utilisateurs), Port 2 = VLAN 20 (Serveurs Web), Port 3 = VLAN 30, Port 4 = VLAN 40 (Identité), Port 5 = VLAN 50 (Management).

3.2 Installation et Partitionnement du Système Pare-feu

Une fois l'infrastructure physique simulée prête, nous procédons à l'installation de l'OS pfSense. Ce système d'exploitation spécialisé, basé sur FreeBSD, est reconnu pour sa stabilité et ses performances réseau. Le choix du système de fichiers est déterminant pour la résilience du pare-feu.

3.2.0 Prérequis : Téléchargements et configuration GNS3

Avant de lancer l'installation, il est nécessaire de télécharger les fichiers requis et de configurer pfSense dans GNS3 :

- **Image ISO de pfSense** : Télécharger depuis <https://atxfiles.pfsense.org/mirror/downloads/>
Nous avons téléchargé pfSense-CE-2.7.2-RELEASE-amd64.iso.gz puis décompressé l'archive avec WinRAR.
- **Disque virtuel vide (qcow2)** : Télécharger depuis <https://sourceforge.net/projects/gns-3/files/Empty%20Qemu%20disk/empty100G.qcow2/download>
Ce disque virtuel de 100Go servira de support de stockage pour l'installation de pfSense.
- **Guide d'installation** : Pour la configuration complète de pfSense dans GNS3, suivre le tutoriel détaillé : <https://getlabsdone.com/how-to-install-pfsense-firewall-on-gns3/>

3.2.1 Amorçage et installation du système

Cette étape couvre le démarrage initial sur l'image ISO et la préparation du disque dur virtuel avec le système de fichiers ZFS, optimisé pour la fiabilité et la robustesse du pare-feu.

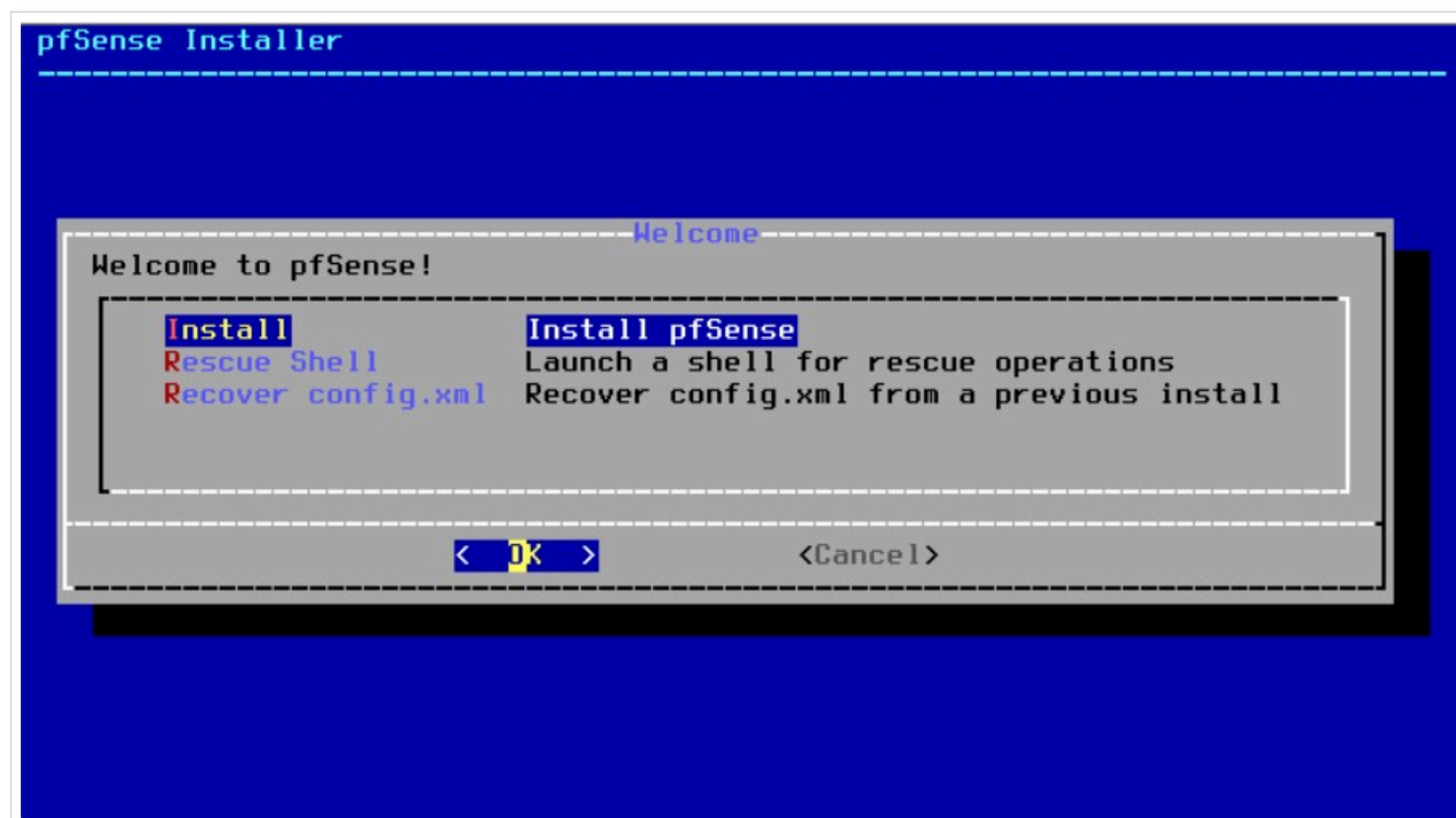


Figure 3.2 - Amorçage de l'installateur.

L'écran d'accueil valide que l'image ISO a bien démarré. Le contrat de licence (Copyright et distribution) nous rappelle que pfSense est une distribution open-source basée sur FreeBSD, un système réputé pour sa stabilité dans les environnements réseau critiques.

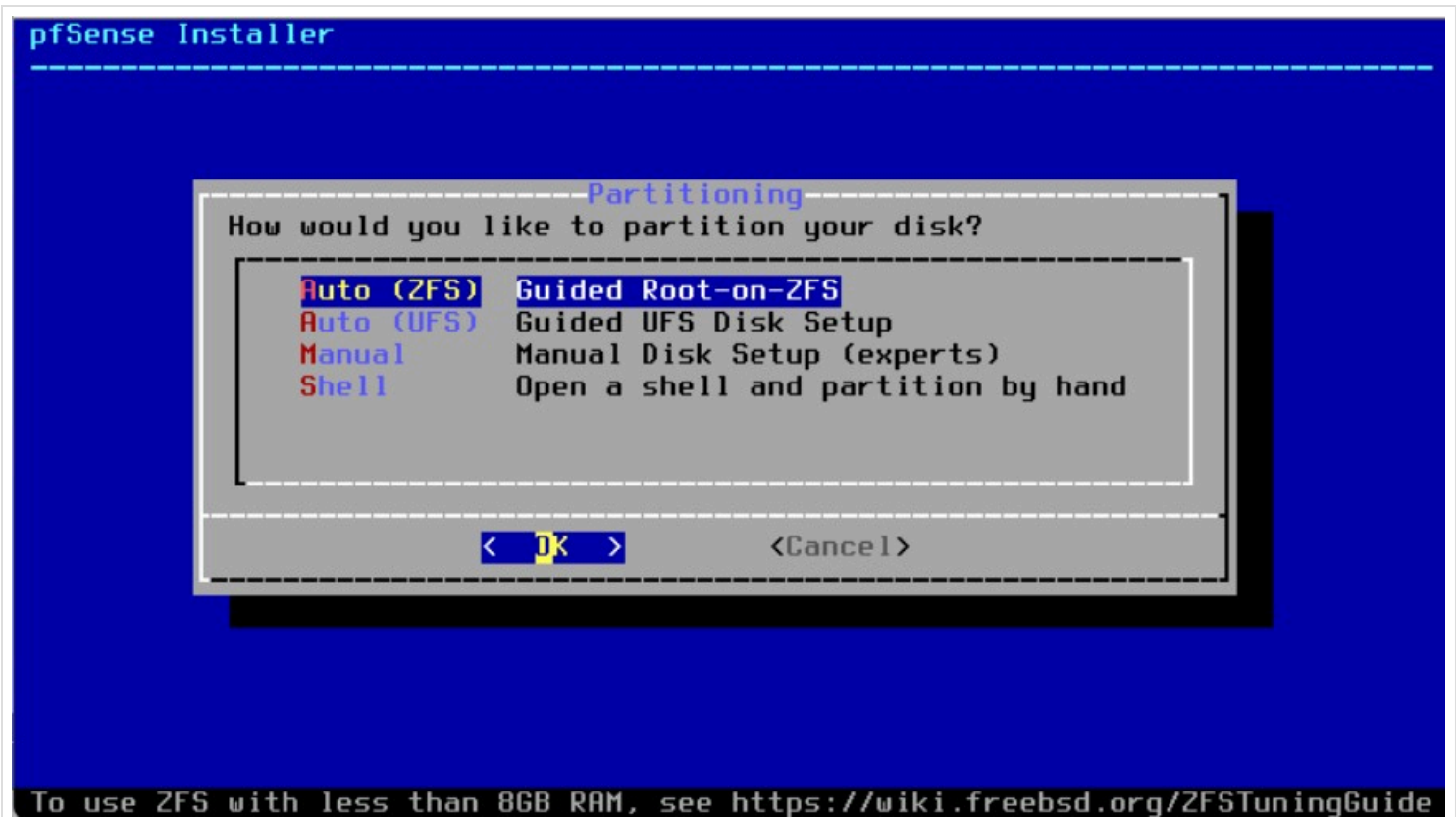
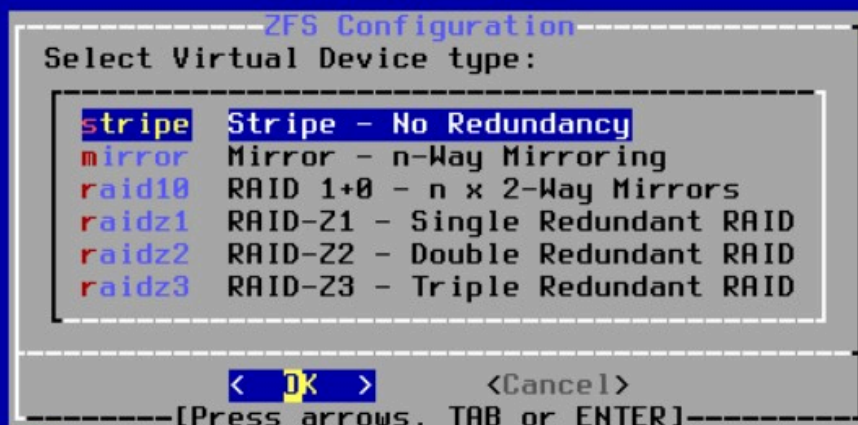


Figure 3.3 - Sélection du partitionnement.

Nous choisissons "Auto (ZFS)". ZFS (Zettabyte File System) est un système de fichiers avancé qui offre des fonctionnalités de correction d'erreurs automatique, de compression, et de snapshots. Ces caractéristiques sont cruciales pour un équipement de sécurité qui doit rester opérationnel 24/7.



[1+ Disks] Striping provides maximum storage but no redundancy

Figure 3.4 - Confirmation et topologie ZFS (Stripe).

Dans notre environnement virtuel à disque unique, la topologie ZFS est "Stripe" (agrégation par bandes). Ce mode offre les meilleures performances en lecture/écriture. En production réelle avec plusieurs disques, un mode "Mirror" (RAID 1) serait privilégié pour la haute disponibilité.

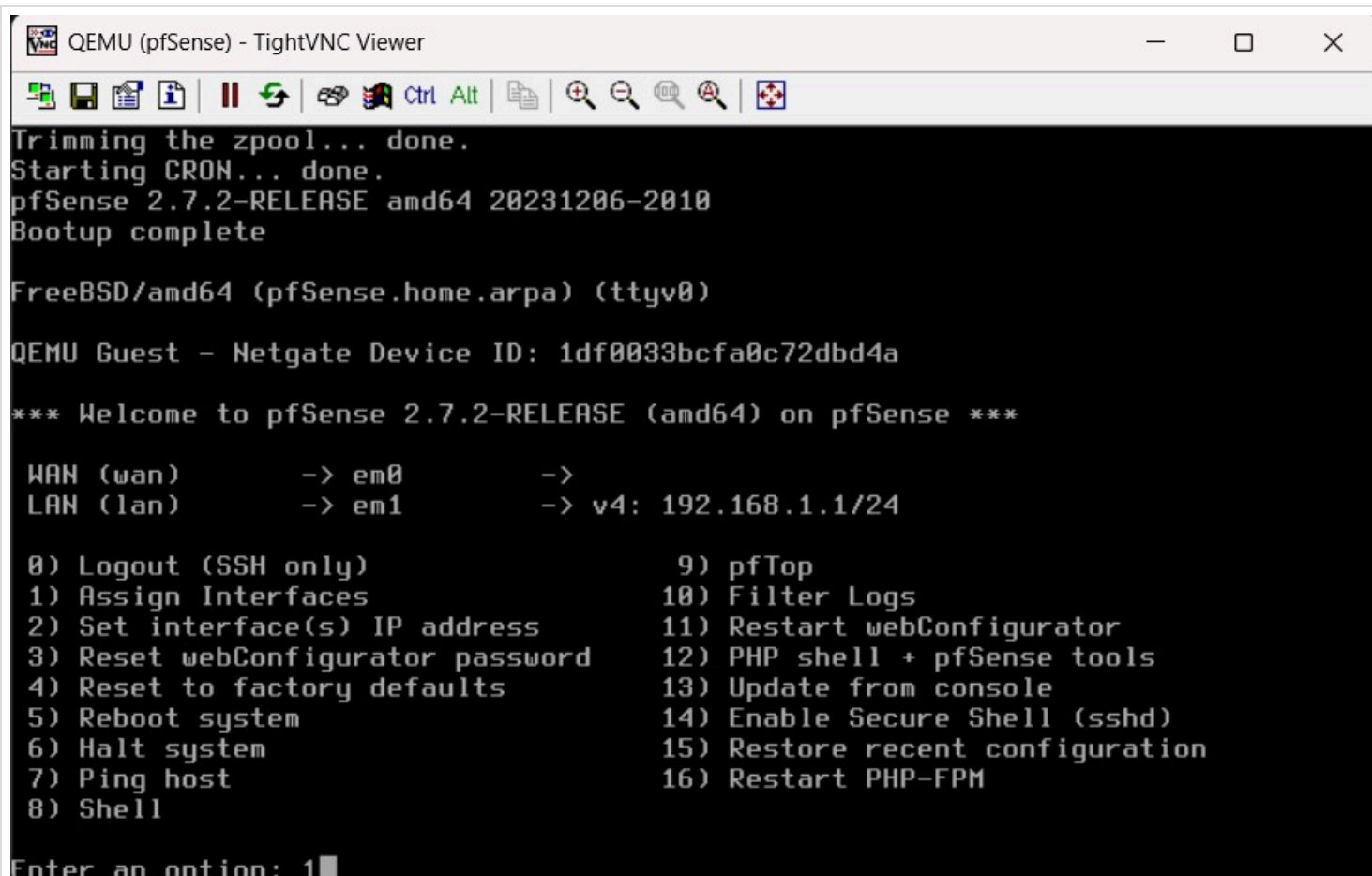


Figure 3.5 - Fin de l'installation.

L'installation des paquets de base est terminée. Le système demande un redémarrage (Reboot) pour charger le noyau configuré depuis le disque dur virtuel au lieu du support d'installation ISO.

3.2.2 Premier démarrage du système

Après l'installation, le système redémarre pour la première fois. Cette phase permet de valider la détection correcte des interfaces réseau physiques avant toute configuration logique.



```
QEMU (pfSense) - TightVNC Viewer
Trimming the zpool... done.
Starting CRON... done.
pfSense 2.7.2-RELEASE amd64 20231206-2010
Bootup complete

FreeBSD/amd64 (pfSense.home.arpa) (ttyv0)
QEMU Guest - Netgate Device ID: 1df0033bcfa0c72dbd4a

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      ->
LAN (lan)      -> em1      -> v4: 192.168.1.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

Enter an option: 1
```

Figure 3.6 - Console d'administration post-démarrage.

Le système est opérationnel. On identifie immédiatement les deux interfaces physiques détectées : **em0** (WAN) qui reçoit une IP via DHCP (connexion Internet/externe) et **em1** (LAN) configurée par défaut en 192.168.1.1. Cette interface LAN sera le point d'ancrage de tous nos VLANs.

3.3 Configuration Initiale des Interfaces (Console)

C'est ici que la segmentation logique est implémentée. Nous allons transformer l'interface physique LAN unique en plusieurs interfaces virtuelles (VLANs). Cette opération se fait via le menu console avant d'accéder à l'interface Web, car nous devons d'abord établir la connectivité réseau de base.

3.3.1 Création des VLANs

La segmentation commence par la déclaration des VLANs au niveau de la console. Nous allons créer les interfaces virtuelles qui correspondront à nos zones de sécurité (Utilisateurs, Serveurs, Management), permettant l'isolation logique du trafic.

```
say no here and use the webConfigurator to configure VLANs later, if required.  
Should VLANs be set up now [y|n]? y
```

Figure 3.7 - Activation des VLANs.

Le système demande "Should VLANs be set up now [y|n]?". Nous répondons **y** (yes) car notre architecture Zero Trust repose sur la micro-segmentation réseau. Sans VLANs, toutes les machines seraient dans le même domaine de diffusion, ce qui est contraire à nos objectifs de sécurité.

```
VLAN Capable interfaces:
```

```
em0      0c:14:50:08:00:00    (up)  
em1      0c:14:50:08:00:01    (up)  
em2      0c:14:50:08:00:02  
em3      0c:14:50:08:00:03  
em4      0c:14:50:08:00:04  
em5      0c:14:50:08:00:05
```

```
Enter the parent interface name for the new VLAN (or nothing if finished): em1
```

Figure 3.8 - Sélection de l'interface parent.

Le système affiche les interfaces capables de supporter les VLANs : **em0** à **em5** avec leurs adresses MAC. Nous sélectionnons **em1** comme interface parent car c'est le port connecté au Trunk du switch. Tous les paquets taggés 802.1Q transiteront par cette interface physique.

```
Enter the parent interface name for the new VLAN (or nothing if finished): em1  
Enter the VLAN tag (1-4094): 10
```

Figure 3.9 - Création du VLAN 10 (Utilisateurs).

Nous entrons le tag **10** pour le premier VLAN. Cela créera l'interface virtuelle **em1.10** correspondant à notre "Zone Utilisateurs". Ce tag 802.1Q permettra au pare-feu d'identifier le trafic de cette zone.

```
Enter the parent interface name for the new VLAN (or nothing if finished): em1  
Enter the VLAN tag (1-4094): 20
```

Figure 3.10 - Création du VLAN 20 (Serveurs).

Nous créons le tag **20** pour la zone des serveurs Web et bases de données. L'isolation de ces serveurs critiques est essentielle : un poste utilisateur compromis devra traverser le pare-feu pour atteindre les serveurs.

```
Enter the parent interface name for the new VLAN (or nothing if finished): em1
Enter the VLAN tag (1-4094): 50
```

Figure 3.11 - Création du VLAN 50 (Management).

Nous créons le tag **50** pour la zone de management et supervision (Wazuh). **Note :** Entre le VLAN 20 et le VLAN 50, nous avons répété cette même procédure pour créer les VLANs 30 (bases de données) et 40 (identité/FreeIPA), comme le confirme le récapitulatif de la Figure 3.12 qui liste les cinq interfaces créées. Seuls les administrateurs autorisés pourront accéder à ce segment réseau isolé.

```
VLAN interfaces:

em1.10      VLAN tag 10, parent interface em1
em1.20      VLAN tag 20, parent interface em1
em1.30      VLAN tag 30, parent interface em1
em1.40      VLAN tag 40, parent interface em1
em1.50      VLAN tag 50, parent interface em1
```

Figure 3.12 - Récapitulatif des VLANs créés.

Le système affiche la liste complète des interfaces VLAN : **em1.10**, **em1.20**, **em1.30**, **em1.40**, et **em1.50**.
Chaque interface virtuelle correspond à une zone de sécurité distincte de notre architecture.

```
Enter the WAN interface name or 'a' for auto-detection
(em0 em1 em2 em3 em4 em5 em1.10 em1.20 em1.30 em1.40 em1.50 or a): em0

Enter the LAN interface name or 'a' for auto-detection
NOTE: this enables full Firewalling/NAT mode.
(em1 em2 em3 em4 em5 em1.10 em1.20 em1.30 em1.40 em1.50 a or nothing if finished
): em1.10
```

Figure 3.13 - Assignation WAN et LAN.

Nous assignons **em0** comme interface WAN (connexion externe). Pour le LAN, nous choisissons **em1.10** (VLAN 10) comme interface LAN principale. Le système note que cela active le mode Firewall/NAT complet.

```

Enter the Optional 1 interface name or 'a' for auto-detection
(em1 em2 em3 em4 em5 em1.20 em1.30 em1.40 em1.50 a or nothing if finished):

The interfaces will be assigned as follows:

WAN   -> em0
LAN   -> em1.10

Do you want to proceed [y/n]? y

```

Figure 3.14 - Confirmation de l'assignation.

Le système récapitule : WAN → **em0**, LAN → **em1.10**. Il demande ensuite l'interface Optional 1. Nous avons terminé l'assignation de base et validons avec **y**.

3.3.2 Configuration des adresses IP

Une fois les interfaces VLAN créées, nous devons leur attribuer un plan d'adressage IP cohérent. Cette étape définit les passerelles par défaut pour chaque sous-réseau, point de passage obligatoire pour le trafic sortant de chaque zone.

```

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      ->
LAN (lan)      -> em1.10   -> v4: 192.168.1.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option: 2

```

Figure 3.15 - Menu principal avec interfaces assignées.

Le menu console montre maintenant WAN (**em0**) et LAN (**em1.10**) avec l'IP par défaut 192.168.1.1/24. Nous sélectionnons l'option 2 pour configurer les adresses IP selon notre plan d'adressage.

```
Available interfaces:

1 - WAN (em0 - dhcp, dhcp6)
2 - LAN (em1.10 - static)

Enter the number of the interface you wish to configure: 2
```

Figure 3.16 - Sélection de l'interface à configurer.

Le système liste les interfaces disponibles : WAN (**em0** - dhcp) et LAN (**em1.10** - static). Nous choisissons l'interface 2 (LAN) pour lui attribuer notre adresse IP personnalisée.

```
Available interfaces:

1 - WAN (em0 - dhcp, dhcp6)
2 - LAN (em1.10 - static)

Enter the number of the interface you wish to configure: 2

Configure IPv4 address LAN interface via DHCP? (y/n) n

Enter the new LAN IPv4 address. Press <ENTER> for none:
> 10.10.10.1

Subnet masks are entered as bit counts (as in CIDR notation) in pfSense.
e.g. 255.255.255.0 = 24
     255.255.0.0   = 16
     255.0.0.0     = 8

Enter the new LAN IPv4 subnet bit count (1 to 32):
> 24
```

Figure 3.17 - Attribution de l'adresse IP LAN.

Nous désactivons le DHCP (réponse **n**) et entrons manuellement l'adresse **10.10.10.1** avec un masque **/24**. Cette adresse sera la passerelle par défaut pour tous les équipements du VLAN 10 (Zone Utilisateurs).


```

For a WAN, enter the new LAN IPv4 upstream gateway address.
For a LAN, press <ENTER> for none:
>

Configure IPv6 address LAN interface via DHCP6? (y/n) n

Enter the new LAN IPv6 address. Press <ENTER> for none:
>

Do you want to enable the DHCP server on LAN? (y/n) y
Enter the start address of the IPv4 client address range: 10.10.10.100
Enter the end address of the IPv4 client address range: 10.10.10.200
Disabling IPv6 DHCPD...

Do you want to revert to HTTP as the webConfigurator protocol? (y/n) n

```

Figure 3.18 - Configuration du serveur DHCP.

Nous activons le serveur DHCP sur le LAN avec la plage **10.10.10.100** à **10.10.10.200**. Les clients du VLAN 10 recevront automatiquement une IP dans cette plage. Le système désactive IPv6 DHCP et demande si on veut revenir au HTTP (nous gardons HTTPS).

```

/ # ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
13: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel qlen 1000
    link/ether 02:42:d5:cc:ae:00 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::42:d5ff:fecc:ae00/64 scope link
        valid_lft forever preferred_lft forever

```

Figure 3.19 - Vérification depuis un client Linux.

Sur une machine cliente, nous exécutons **ip a** pour vérifier la configuration réseau. L'interface **eth0** est visible et prête à recevoir une adresse du réseau 10.10.10.0/24. Cette étape valide la connectivité entre le client et le pare-feu.

```
/ # ip addr add 10.10.10.100/24 dev eth0
/ # ip route add default via 10.10.10.1
/ # ping 10.10.10.1
PING 10.10.10.1 (10.10.10.1): 56 data bytes
64 bytes from 10.10.10.1: seq=0 ttl=64 time=5.158 ms
64 bytes from 10.10.10.1: seq=1 ttl=64 time=2.139 ms
64 bytes from 10.10.10.1: seq=2 ttl=64 time=2.283 ms
^C
--- 10.10.10.1 ping statistics ---
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max = 2.139/3.193/5.158 ms
/ #
```

Figure 3.20 - Test de connectivité réussi.

Nous configurons l'IP **10.10.10.100/24** sur le client, ajoutons la route par défaut via **10.10.10.1**, puis effectuons un ping vers la passerelle. Les 3 paquets sont reçus avec 0% de perte : la communication avec pfSense est établie.

3.4 Premier Accès et Assistant de Configuration (Web)

Une fois le réseau de base fonctionnel, l'administration se poursuit via l'interface Web pour paramétrer les services essentiels.

3.4.1 Connexion à l'interface Web

L'administration du pare-feu bascule vers l'interface graphique (WebGUI). La première connexion permet d'initialiser les paramètres globaux via l'assistant de configuration, sécurisant l'accès administrateur et définissant les paramètres de base.

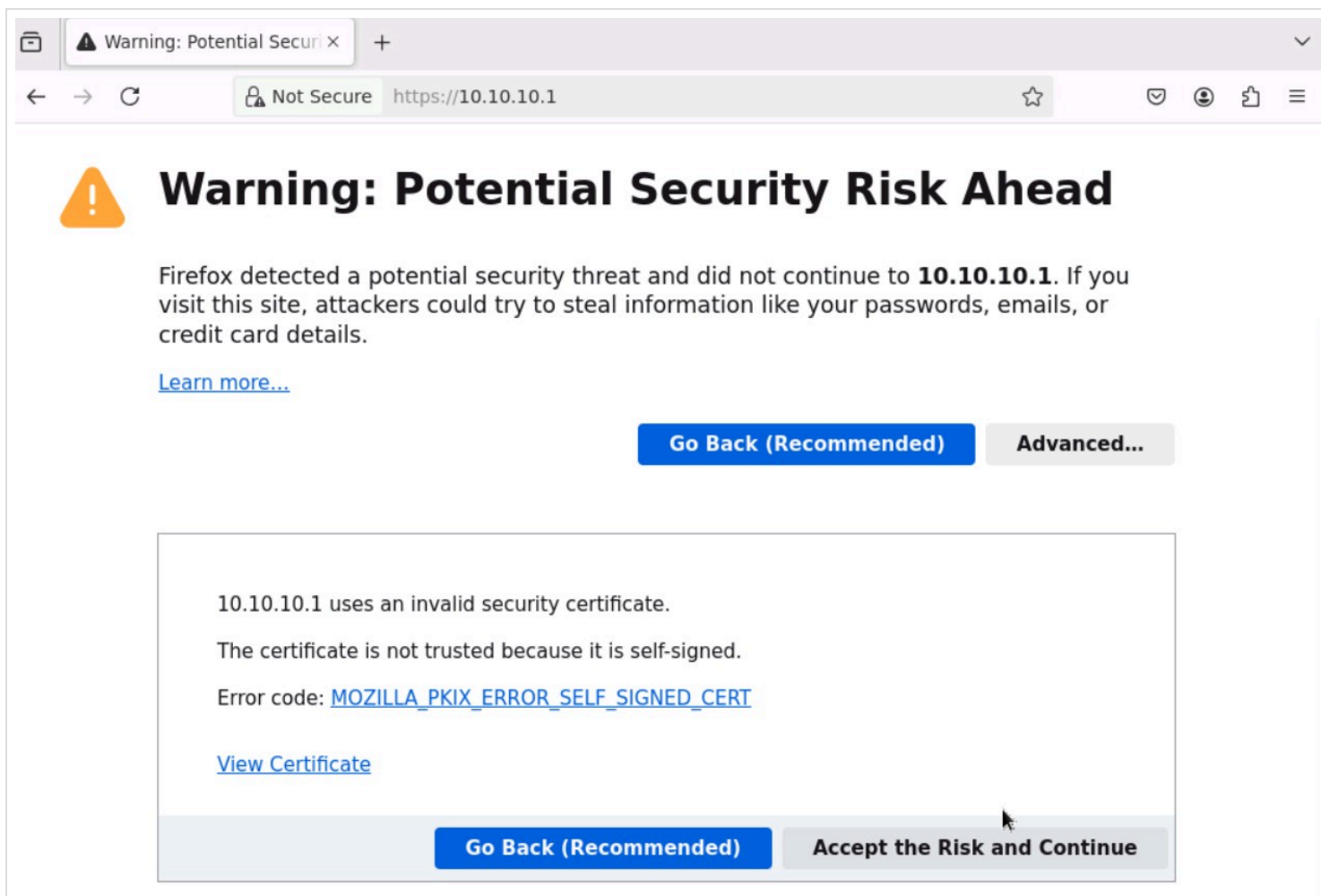


Figure 3.21 - Avertissement de sécurité HTTPS.

Lors de la première connexion à **https://10.10.10.1**, Firefox affiche un avertissement "Potential Security Risk Ahead". Le certificat est auto-signé (self-signed), ce qui est normal pour une installation fraîche. Nous cliquons sur "Accept the Risk and Continue" pour poursuivre.

SIGN IN

SIGN IN

Figure 3.22 - Page de connexion pfSense.

L'interface Web de pfSense apparaît avec sa page de login caractéristique sur fond bleu foncé. Nous nous connectons avec les identifiants par défaut : **admin** / **pfsense**. Il sera impératif de changer ce mot de passe dans l'assistant de configuration.

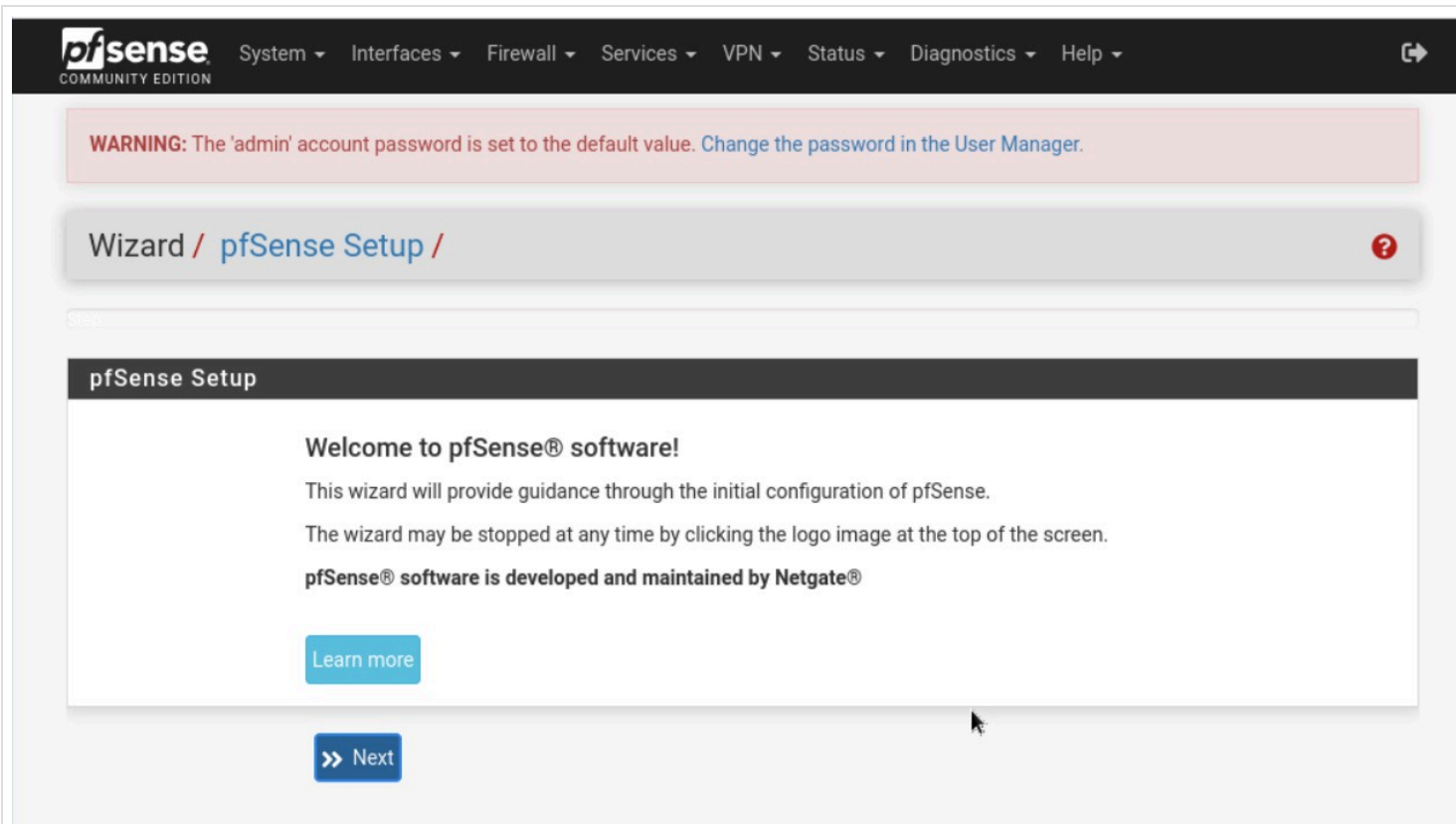


Figure 3.23 - Assistant de configuration (Setup Wizard).

Après la connexion, le Setup Wizard démarre automatiquement. Un bandeau rouge avertit que le mot de passe admin est toujours celui par défaut. L'assistant guidera la configuration des paramètres essentiels : DNS, NTP, timezone, et changement de mot de passe.

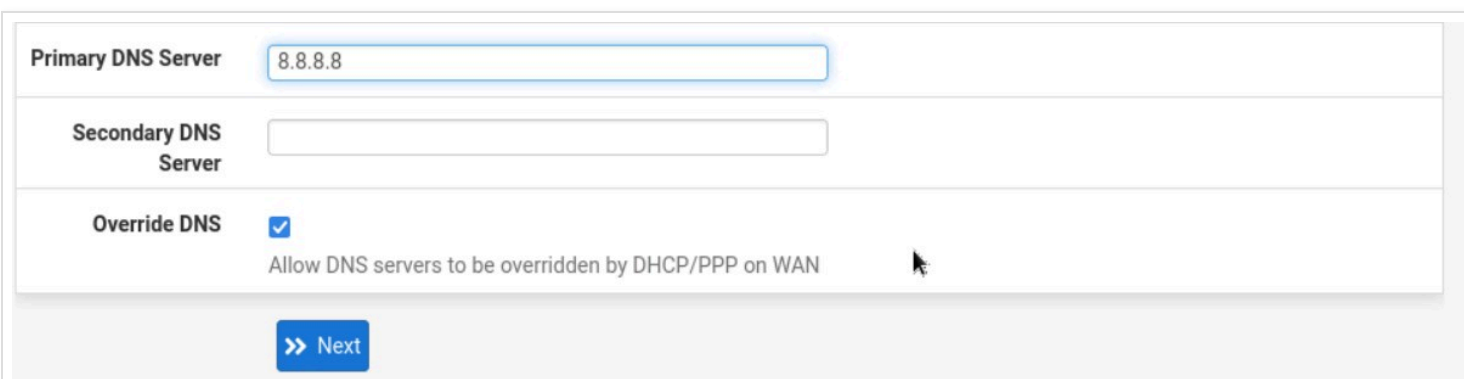


Figure 3.24 - Configuration du serveur DNS.

Nous configurons le DNS primaire à **8.8.8.8** (Google DNS). L'option "Override DNS" est cochée pour permettre au DHCP du WAN de fournir des serveurs DNS alternatifs si disponibles. Un DNS fiable est essentiel pour la résolution de noms sur le réseau.

Time Server Information	
Please enter the time, date and time zone.	
Time server hostname	2.pfsense.pool.ntp.org Enter the hostname (FQDN) of the time server.
Timezone	Etc/GMT0

Figure 3.25 - Configuration du serveur NTP et fuseau horaire.

Le serveur NTP est configuré sur **2.pfsense.pool.ntp.org** et le fuseau horaire sur **Etc/GMT0**. Une synchronisation horaire précise est critique pour les logs de sécurité, les certificats SSL et la corrélation d'événements dans Wazuh.

3.4.2 Configuration des Services Réseau

Nous configurons ici les services d'infrastructure essentiels comme le DNS pour la résolution de noms et le NTP pour la synchronisation horaire, prérequis indispensables pour la sécurité (logs, Kerberos) et le bon fonctionnement du réseau.

RFC1918 Networks	
Block RFC1918 Private Networks	☐ Block private networks from entering via WAN When set, this option blocks traffic from IP addresses that are reserved for private networks as per RFC 1918 (10/8, 172.16/12, 192.168/16) as well as loopback addresses (127/8). This option should generally be left turned on, unless the WAN network lies in such a private address space, too.
Block bogon networks	
Block bogon networks	☐ Block non-Internet routed networks from entering via WAN When set, this option blocks traffic from IP addresses that are reserved (but not RFC 1918) or not yet assigned by IANA. Bogons are prefixes that should never appear in the Internet routing table, and obviously should not appear as the source address in any packets received.

Figure 3.26 - Options de sécurité WAN (RFC1918 et Bogons).

Nous **décochons** les deux options de blocage sur l'interface WAN :

- **Block RFC1918 Private Networks** : bloque les adresses privées (10.x, 172.16.x, 192.168.x)
- **Block bogon networks** : bloque les adresses non routables sur Internet

Pourquoi décocher ? Dans notre environnement virtualisé, l'interface WAN est connectée au réseau NAT de VirtualBox qui utilise des adresses privées (ex: 10.0.2.x). Si ces options étaient cochées, pfSense bloquerait tout le trafic WAN entrant, empêchant l'accès à Internet. En production avec une vraie IP publique, ces options devraient être activées pour protéger contre les attaques de spoofing.



Figure 3.27 - Rechargement de la configuration.

L'assistant demande de recharger la configuration pour appliquer tous les changements. En cliquant sur "Reload", pfSense appliquera les nouveaux paramètres DNS, NTP, et les options de sécurité configurées précédemment.

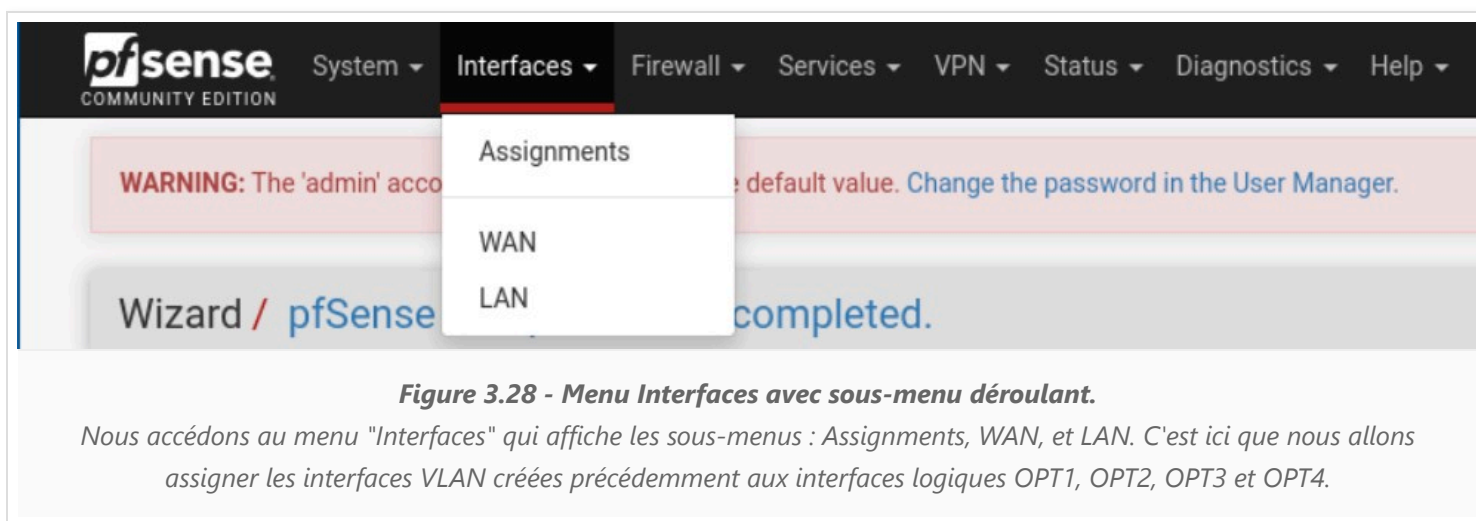


Figure 3.28 - Menu Interfaces avec sous-menu déroulant.

Nous accédons au menu "Interfaces" qui affiche les sous-menus : Assignments, WAN, et LAN. C'est ici que nous allons assigner les interfaces VLAN créées précédemment aux interfaces logiques OPT1, OPT2, OPT3 et OPT4.

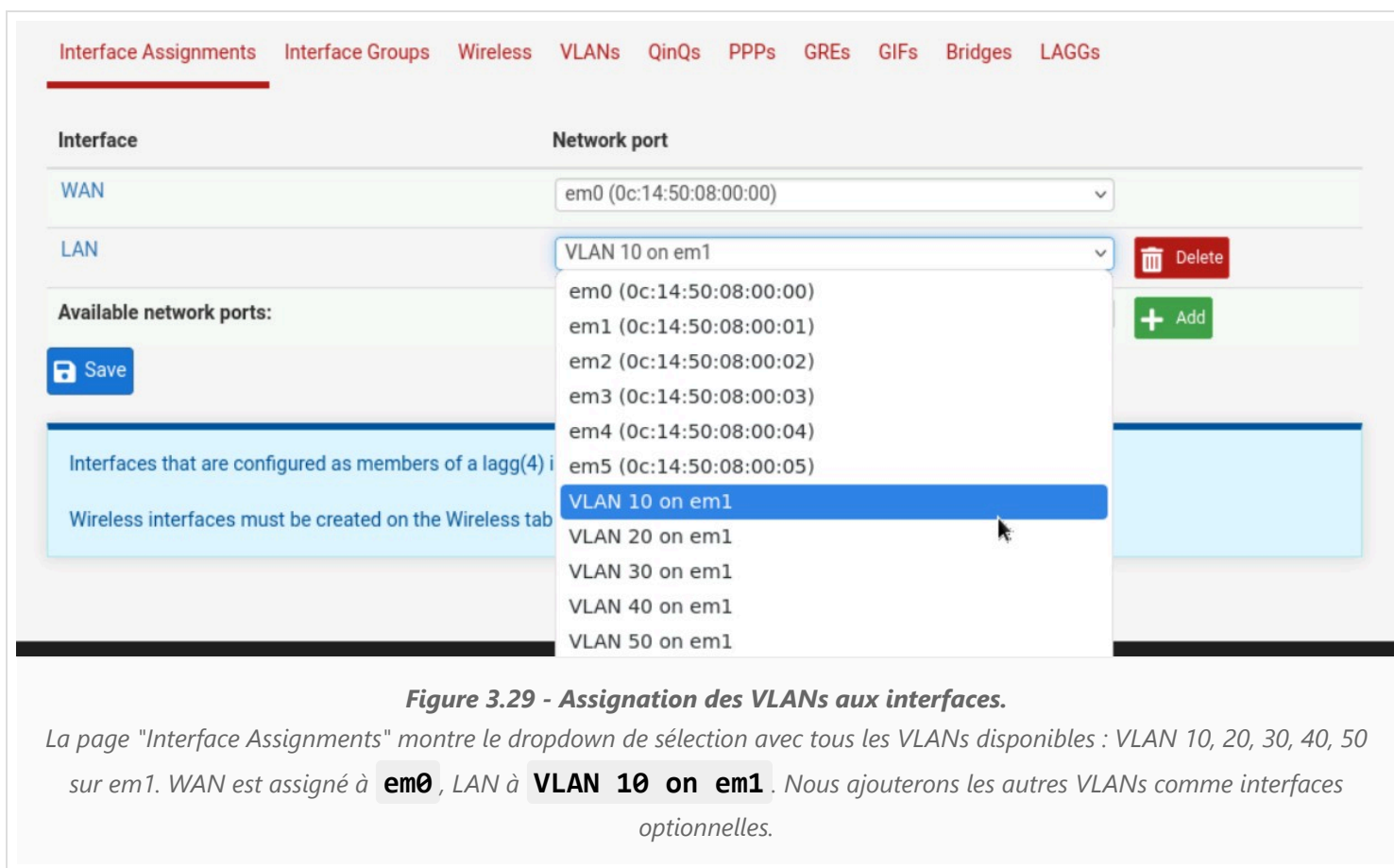


Figure 3.29 - Assignment des VLANs aux interfaces.

La page "Interface Assignments" montre le dropdown de sélection avec tous les VLANs disponibles : VLAN 10, 20, 30, 40, 50 sur em1. WAN est assigné à **em0**, LAN à **VLAN 10 on em1**. Nous ajouterons les autres VLANs comme interfaces optionnelles.

3.5 Configuration des Interfaces VLAN dans l'Interface Web

Après l'assistant initial, nous assignons et configurons chaque VLAN comme interface distincte dans pfSense pour permettre le routage inter-VLAN et l'application des règles de pare-feu.

3.5.1 Assignment des VLANs aux interfaces

Les VLANs déclarés en console doit maintenant être mappés à des interfaces logiques dans pfSense pour pouvoir y appliquer des règles de pare-feu et des services. C'est ici que la correspondance physique/logique est établie.

Interface	Network port	
WAN	em0 (0c:14:50:08:00:00)	
LAN	VLAN 10 on em1	Delete
OPT1	VLAN 20 on em1	Delete
OPT2	VLAN 30 on em1	Delete
OPT3	VLAN 40 on em1	Delete
OPT4	VLAN 50 on em1	Delete
Available network ports:	em1 (0c:14:50:08:00:01)	Add

Save

Figure 3.30 - Vue complète des interfaces assignées.

Tous les VLANs sont maintenant assignés : WAN → **em0**, LAN → **VLAN 10**, OPT1 → **VLAN 20**, OPT2 → **VLAN 30**, OPT3 → **VLAN 40**, OPT4 → **VLAN 50**. Le bouton "Save" enregistrera cette configuration.

Interfaces / OPT1 (em1.20)

General Configuration

Enable ☒ Enable interface

Description

Enter a description (name) for the interface here.

Figure 3.31 - Activation de l'interface OPT1 (DMZ_WEB).

L'interface OPT1 est activée en cochant la case "Enable interface". Cette interface est renommée en "DMZ_WEB" pour identifier clairement le VLAN 20 destiné à héberger les serveurs web. Le renommage des interfaces est une bonne pratique qui améliore la lisibilité des règles de pare-feu et facilite la maintenance du système. Dans le modèle Zero Trust, chaque zone doit être clairement identifiée.

3.5.2 Configuration IP des interfaces

Chaque interface logique reçoit sa configuration IPv4 statique. Ces adresses serviront de passerelle par défaut pour les machines de chaque zone respective, assurant le routage centralisé via pfSense.

Interfaces / OPT1 (em1.20)

General Configuration

Enable ☒ Enable interface

Description

DMZ_WEB

Enter a description (name) for the interface here.

IPv4 Configuration
Type

Static IPv4

Figure 3.32 - Configuration IPv4 statique.

Le type de configuration IPv4 est défini sur "Static IPv4" pour attribuer une adresse IP fixe à cette interface. Contrairement à DHCP, une adresse statique garantit que la passerelle du VLAN aura toujours la même adresse IP, ce qui est essentiel pour la stabilité du routage et la définition des règles de pare-feu. Cette configuration est obligatoire pour un firewall jouant le rôle de routeur inter-VLAN.

Static IPv4 Configuration

IPv4 Address

10.10.20.1

/ 24

IPv4 Upstream
gateway

None

+ Add a new gateway

If this interface is an Internet connection, select an existing Gateway from the list or add a new one using the "Add" button.
On local area network interfaces the upstream gateway should be "none".
Selecting an upstream gateway causes the firewall to treat this interface as a [WAN type interface](#).
Gateways can be managed by [clicking here](#).

Figure 3.33 - Attribution de l'adresse IP 10.10.20.1/24.

L'interface DMZ_WEB reçoit l'adresse **10.10.20.1/24**. Cette adresse sera la passerelle par défaut pour tous les équipements du VLAN 20 (réseau 10.10.20.0/24). Le masque /24 (255.255.255.0) permet d'avoir jusqu'à 254 hôtes dans ce segment. L'adresse .1 est conventionnellement utilisée pour la passerelle, facilitant la mémorisation et le dépannage réseau.

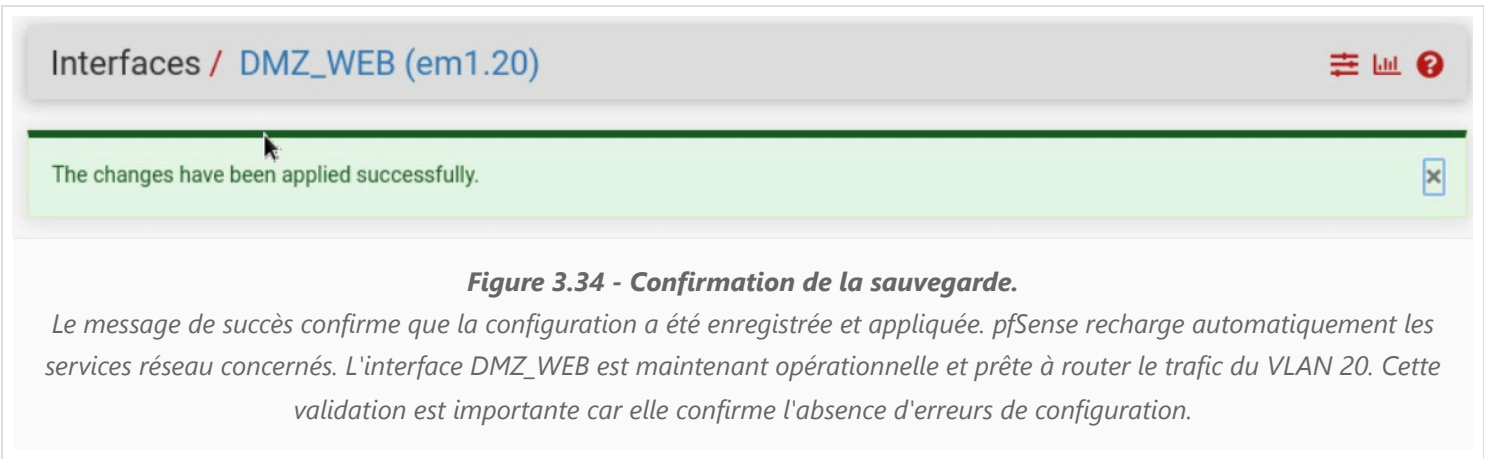


Figure 3.34 - Confirmation de la sauvegarde.

Le message de succès confirme que la configuration a été enregistrée et appliquée. pfSense recharge automatiquement les services réseau concernés. L'interface DMZ_WEB est maintenant opérationnelle et prête à router le trafic du VLAN 20. Cette validation est importante car elle confirme l'absence d'erreurs de configuration.

DMZ_WEB	VLAN 20 on em1	 Delete
OPT2	VLAN 30 on em1	 Delete
OPT3	VLAN 40 on em1	 Delete
OPT4	VLAN 50 on em1	 Delete
Available network ports:	em1 (0c:14:50:08:00:01)	 Add

Figure 3.35 - Vue des interfaces assignées.

L'écran "Interface Assignments" affiche la correspondance entre les interfaces logiques et physiques. Nous voyons : WAN (em0), LAN (em1.10), et les interfaces optionnelles OPT1 à OPT4 assignées aux VLANs em1.20, em1.30, em1.40, em1.50. Cette vue permet de vérifier que chaque VLAN est correctement associé à une interface pfSense avant de procéder à la configuration IP et aux règles.

Interface Assignments Interface Groups Wireless VLANs QinQs PPPs GREs GIFs Bridges LAGGs		
Interface	Network port	
WAN	em0 (0c:14:50:08:00:00)	
LAN	VLAN 10 on em1	Delete
DMZ_WEB	VLAN 20 on em1	Delete
DATA	VLAN 30 on em1	Delete
IDENTITY	VLAN 40 on em1	Delete
SIEM	VLAN 50 on em1	Delete
Available network ports:	em1 (0c:14:50:08:00:01)	+ Add

Figure 3.36 - Liste finale des interfaces.

Le menu Interfaces affiche toutes les interfaces configurées avec leurs noms personnalisés : **LAN** (postes utilisateurs), **DMZ_WEB** (serveurs web), **DATA** (bases de données), **IDENTITY** (FreeIPA), **SIEM** (Wazuh). Ces noms explicites facilitent la création et la lecture des règles de pare-feu, élément clé dans une architecture Zero Trust.

3.6 Phase de Test : Validation de la Connectivité

Avant d'appliquer les règles Zero Trust restrictives, il est essentiel de valider que toutes les interfaces et VLANs sont correctement configurés et peuvent communiquer. Pour cela, nous créons des **règles temporaires autorisant tout le trafic** (Protocol: Any, Source: Any, Destination: Any) sur chaque interface. Ces règles permettent de tester la connectivité entre les différents segments réseau via des commandes ping et de confirmer que le routage inter-VLAN fonctionne. **Cette phase est également cruciale pour télécharger et installer tous les paquets nécessaires** (mises à jour système, dépendances logicielles, outils de sécurité) sur chaque serveur avant de restreindre l'accès Internet. **Ces règles seront supprimées après les tests** et remplacées par les règles Zero Trust définitives.

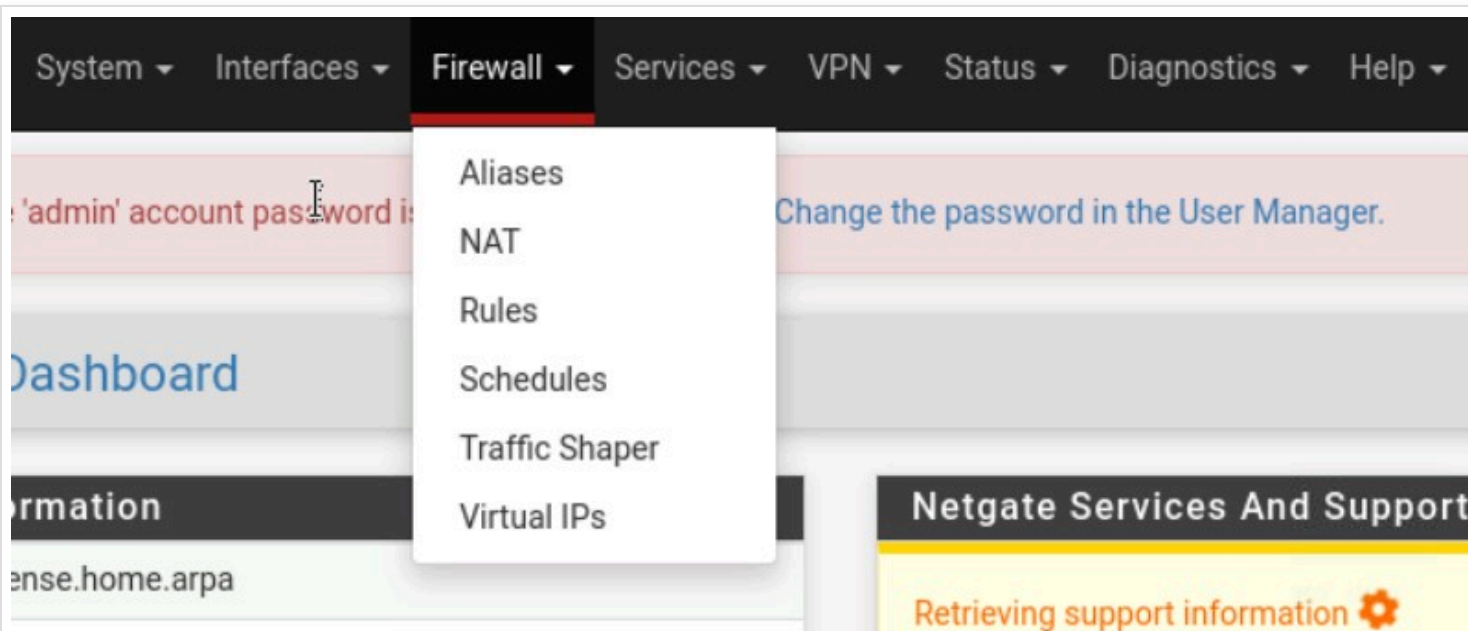


Figure 3.37 - Création de règles temporaires (Allow All).

Accès au menu Firewall > Rules. Pour chaque interface (LAN, DMZ_WEB, DATA, IDENTITY, SIEM), nous créons une règle temporaire avec Action "Pass", Protocol "Any", Source "Any", Destination "Any". Cette configuration permissive permet de valider la connectivité avant d'appliquer les restrictions Zero Trust.

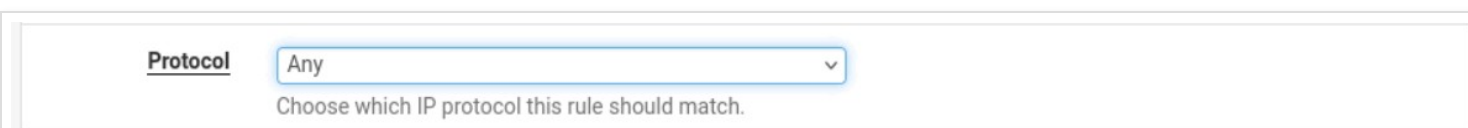


Figure 3.38 - Protocole "Any" pour les tests.

Le protocole est défini sur "Any" pour autoriser tous les types de trafic (TCP, UDP, ICMP). Cette configuration est **temporaire et non sécurisée** — elle sert uniquement à valider que le routage fonctionne correctement entre les VLANs avant d'appliquer les règles restrictives.

3.6.1 Règles temporaires par interface

Nous appliquons une règle "Allow All" sur chaque interface VLAN. Ces captures montrent la configuration de chaque onglet avec la règle permissive.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 *	*	*	*	*	*	none		    

Figure 3.39 - Règle temporaire sur DATA.

Onglet DATA (VLAN 30) : une règle IPv4 "Pass Any to Any" est configurée. Cette règle autorise temporairement tout le trafic sortant du segment DATA pour les tests de connectivité. Elle sera remplacée par des règles restrictives.

Floating WAN LAN DMZ_WEB DATA IDENTITY SIEM

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 *	*	*	*	*	*	none		    

Figure 3.40 - Règle temporaire sur IDENTITY.

Onglet IDENTITY (VLAN 40) : règle "Pass Any to Any" configurée. Le segment IDENTITY hébergera FreeIPA, mais pour l'instant nous testons simplement que les machines de ce VLAN peuvent communiquer avec les autres.

Floating WAN LAN DMZ_WEB DATA IDENTITY SIEM

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 *	*	*	*	*	*	none		    

Figure 3.41 - Règle temporaire sur SIEM.

Onglet SIEM (VLAN 50) : règle "Pass Any to Any" configurée. Cette règle permissive permet de valider que le segment SIEM peut communiquer avec tous les autres VLANs avant de restreindre les flux.

Floating WAN LAN DMZ_WEB DATA IDENTITY SIEM

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 *	*	*	*	*	*	none		    

Figure 3.42 - Confirmation des règles temporaires.

Vue confirmant que les règles "Allow All" sont actives sur les différentes interfaces. Ces règles sont identifiées par leur action "Pass" et leur destination "*" (any), indiquant qu'elles autorisent tout le trafic.

3.6.2 Tests de connectivité inter-VLAN

Avec les règles temporaires en place, nous testons la connectivité depuis chaque VLAN vers sa passerelle pfSense et vers Internet (8.8.8.8). Un ping réussi confirme que le routage et le NAT fonctionnent correctement.

Cancel

Wired

Apply

DetailsIdentityIPv4IPv6Security

IPv4 Method

Automatic (DHCP)

Manual

Shared to other computers

Link-Local Only

Disable

Addresses

Address	Netmask	Gateway	
10.10.50.10	24	10.10.50.1	

DNS

Automatic

8.8.8.8

Separate IP addresses with commas

Figure 3.43 - Configuration IP du client de test SIEM.
Configuration réseau d'une machine de test dans le VLAN SIEM : IP **10.10.50.10**, masque **/24**, passerelle **10.10.50.1** (pfSense), DNS **8.8.8.8**. Cette machine servira à valider la connectivité du segment SIEM.


```
/ # ip addr add 10.10.10.100/24 dev eth0
/ # ip route add default via 10.10.10.1
/ # ping 10.10.10.1
PING 10.10.10.1 (10.10.10.1): 56 data bytes
64 bytes from 10.10.10.1: seq=0 ttl=64 time=5.158 ms
64 bytes from 10.10.10.1: seq=1 ttl=64 time=2.139 ms
64 bytes from 10.10.10.1: seq=2 ttl=64 time=2.283 ms
```

Figure 3.44 - Test connectivité LAN.

Depuis un conteneur LAN (IP **10.10.10.100/24**), ping vers la passerelle **10.10.10.1** réussi. Le TTL=64 confirme une réponse directe de pfSense. **Résultat : ✓ LAN opérationnel.**

```
/ # ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8): 56 data bytes
64 bytes from 8.8.8.8: seq=0 ttl=127 time=71.545 ms
64 bytes from 8.8.8.8: seq=1 ttl=127 time=66.512 ms
^C
--- 8.8.8.8 ping statistics ---
2 packets transmitted, 2 packets received, 0% packet loss
```

Figure 3.45 - Test accès Internet depuis LAN.

Ping vers **8.8.8.8** (Google DNS) réussi avec 0% de perte. Ce test valide que le NAT fonctionne et que le LAN peut accéder à Internet. **Résultat : ✓ NAT opérationnel.**

```
/ # ip addr add 10.10.20.20/24 dev eth0
/ # ip route add default via 10.10.20.1
/ # ping 10.10.20.1
PING 10.10.20.1 (10.10.20.1): 56 data bytes
64 bytes from 10.10.20.1: seq=0 ttl=64 time=5.300 ms
64 bytes from 10.10.20.1: seq=1 ttl=64 time=2.395 ms
^C
--- 10.10.20.1 ping statistics ---
2 packets transmitted, 2 packets received, 0% packet loss
round-trip min/avg/max = 2.395/3.847/5.300 ms
```

Figure 3.46 - Test connectivité DMZ_WEB.

Depuis le segment DMZ_WEB (IP **10.10.20.20/24**), ping vers la passerelle **10.10.20.1** réussi. Le VLAN 20 destiné aux serveurs web est opérationnel. **Résultat : ✓ DMZ_WEB opérationnel.**


```

/ # ip addr add 10.10.30.30/24 dev eth0
/ # ip route add default via 10.10.30.1
/ # ping 10.10.30.1
PING 10.10.30.1 (10.10.30.1): 56 data bytes
64 bytes from 10.10.30.1: seq=0 ttl=64 time=3.513 ms
64 bytes from 10.10.30.1: seq=1 ttl=64 time=1.607 ms
^C
--- 10.10.30.1 ping statistics ---
2 packets transmitted, 2 packets received, 0% packet loss
round-trip min/avg/max = 1.607/2.560/3.513 ms
/ # ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8): 56 data bytes
64 bytes from 8.8.8.8: seq=0 ttl=127 time=64.891 ms
64 bytes from 8.8.8.8: seq=1 ttl=127 time=70.825 ms
^C
--- 8.8.8.8 ping statistics ---
2 packets transmitted, 2 packets received, 0% packet loss
round-trip min/avg/max = 64.891/67.858/70.825 ms
/ # █

```

Figure 3.47 - Test connectivité DATA.

Depuis le segment DATA (IP **10.10.30.30/24**), ping vers la passerelle **10.10.30.1** et vers Internet (**8.8.8.8**) réussis. **Résultat : ✓ DATA opérationnel.**

Cancel

Wired

Apply

Details

Identity

IPv4

IPv6

Security

IPv4 Method

☐ Automatic (DHCP)
☐ Link-Local Only
☒ Manual
☐ Disable
☐ Shared to other computers

Addresses

Address	Netmask	Gateway	
10.10.50.10	255.255.255.0	10.10.50.1	

Figure 3.48 - Configuration réseau SIEM (détails).

Vue détaillée de la configuration IP manuelle du serveur dans le VLAN SIEM : IP **10.10.50.10**, masque **255.255.255.0**, passerelle **10.10.50.1**. Préparation pour le test de connectivité du segment SIEM.

```

practice@practice:~$ ping 10.10.50.1
PING 10.10.50.1 (10.10.50.1) 56(84) bytes of data.
64 bytes from 10.10.50.1: icmp_seq=1 ttl=64 time=5.07 ms
64 bytes from 10.10.50.1: icmp_seq=2 ttl=64 time=5.52 ms
64 bytes from 10.10.50.1: icmp_seq=3 ttl=64 time=5.29 ms
^C
--- 10.10.50.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 5.065/5.294/5.524/0.187 ms
practice@practice:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=127 time=68.7 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=127 time=69.5 ms
^C
--- 8.8.8.8 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 68.671/69.095/69.520/0.424 ms

```

Figure 3.49 - Test connectivité SIEM.

Depuis le segment SIEM, ping vers la passerelle **10.10.50.1** et vers Internet (**8.8.8.8**) réussis. Tous les VLANs sont maintenant validés. **Résultat : ✓ SIEM opérationnel. Tous les segments sont connectés !**

⚠ Important : Les règles "Allow All" utilisées pour ces tests sont maintenant **supprimées**. Nous allons les remplacer par les règles Zero Trust définitives qui n'autorisent que les flux strictement nécessaires.

3.7 Définition des Règles de Pare-feu (Zero Trust)

Après validation de la connectivité, nous supprimons les règles temporaires et créons les règles Zero Trust définitives. Chaque règle autorise uniquement un flux spécifique (source, destination, port), et une règle finale "Block All" bloque tout le reste.

3.7.1 Création des règles et alias

La mise en place du modèle Zero Trust commence ici. Nous définissons d'abord des alias pour grouper les ports et IP, ce qui simplifiera grandement la création et la lecture des règles de filtrage par flux.

Firewall / Rules / Edit

Edit Firewall Rule

Action

Pass

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled

☐ Disable this rule

Set this option to disable this rule without removing it from the list.

Interface

LAN

Choose the interface from which packets must come to match this rule.

Address Family

IPv4

Select the Internet Protocol version this rule applies to.

Protocol

TCP

Choose which IP protocol this rule should match.

Figure 3.50 - Création d'une règle firewall Zero Trust.

Formulaire de création de règle pfSense. Les champs clés sont : **Action** "Pass" (autoriser), **Interface** "LAN" (trafic entrant sur le LAN), **Protocol** "TCP", **Address Family** "IPv4". Cette règle définit quel type de trafic sera traité et sur quelle interface.
Dans pfSense, les règles sont appliquées sur le trafic ENTRANT sur une interface.

Source

Source

☐ Invert match

LAN address

Source Address

Display Advanced

The **Source Port Range** for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, **any**.

Destination

Destination

☐ Invert match

DMZ_WEB address

Destination Address

Destination Port Range

(other)

80

(other)

443

From

Custom

To

Custom

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log

☐ Log packets that are handled by this rule

Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the [Status: System Logs: Settings](#) page).

Description

Access Web App

A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.

Advanced Options

Display Advanced

Figure 3.51 - Définition Source/Destination de la règle.

Configuration complète de la règle : **Source** "LAN address" (tout le réseau LAN), **Destination** "DMZ_WEB address" (le segment web), **Destination Ports** 80 à 443 (HTTP et HTTPS). La **Description** "Access Web App" documente la règle. Cette règle autorise les utilisateurs du LAN à accéder aux applications web hébergées dans la DMZ, tout en bloquant les autres types d'accès.

Firewall / Aliases / Ports

IP

Ports

URLs

All

Firewall Aliases Ports				
Name	Type	Values	Description	Actions
Identity_Ports	Port(s)	53, 88, 123, 389, 464, 636	Ports pour FreeIPA (DNS, Kerberos, LDAP)	  
Ports_Wazuh	Port(s)	1514, 1515	Agent Wazuh vers Manager	  
Ports_Web	Port(s)	80, 443	ACCES WEB	  

Figure 3.52 - Aliases de ports configurés.

Les **Aliases** simplifient la gestion des règles en regroupant plusieurs ports sous un nom descriptif. Trois alias sont définis : **Identity_Ports** (53 DNS, 88 Kerberos, 389/636 LDAP) pour FreeIPA, **Ports_Wazuh** (1514 agent, 1515 enregistrement) pour le SIEM, **Ports_Web** (80 HTTP, 443 HTTPS) pour les serveurs web. L'utilisation d'alias est une bonne pratique pour la maintenance et la lisibilité.

3.7.2 Règles appliquées par interface

Firewall / Rules / LAN

Floating WAN LAN DMZ_WEB DATA IDENTITY SIEM

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	✓ 0/996 KiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	
☐	✓ 0/0 B	IPv4 TCP	LAN address	*	DMZ_WEB address	Ports_Web	*	none		Acces Serveur Web	
☐	✓ 0/0 B	IPv4 TCP/UDP	LAN address	*	IDENTITY address	Identity_Ports	*	none		Acces Freeipa	
☐	✓ 0/0 B	IPv4 TCP	LAN address	*	SIEM address	Ports_Wazuh	*	none		Acces Wazuh	
☐	✗ 0/0 B	IPv4 *	*	*	*	*	*	none		Zero Trust	

Figure 3.53 - Règles LAN complètes (Zero Trust).

Ensemble des règles appliquées sur l'interface LAN, dans l'ordre d'évaluation :

- 1. Anti-Lockout Rule (empêche de se verrouiller hors de l'interface web)
- 2. Acces Serveur Web (LAN → DMZ_WEB ports 80,443)
- 3. Acces Freeipa (LAN → IDENTITY ports identity)
- 4. Acces Wazuh (LAN → SIEM ports 443,1514,1515)
- 5. Zero Trust BLOCK (bloquer tout le reste)

Cette dernière règle est fondamentale : elle bloque tout trafic non explicitement autorisé.

The changes have been applied successfully. The firewall rules are now reloading in the background.
[Monitor the filter reload progress.](#)

Floating WAN LAN **DMZ_WEB** DATA IDENTITY SIEM

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐		0/0 B	IPv4 TCP	DMZ_WEB address	*	DATA address	5432	*	none	Acces Base de donnee	
☐		0/0 B	IPv4 TCP/UDP	DMZ_WEB address	*	IDENTITY address	Identity_Ports	*	none	Acces Freeipa	
☐		0/0 B	IPv4 TCP	DMZ_WEB address	*	SIEM address	Ports_Wazuh	*	none	Acces Wazuh	
☐		0/0 B	IPv4 *	*	*	*	*	none		Zero Trust	

Figure 3.54 - Règles DMZ_WEB appliquées (Zero Trust).

Règles pour le segment DMZ_WEB hébergeant les serveurs applicatifs :

1. Acces DB (DMZ_WEB → DATA port 5432 PostgreSQL)
2. Acces Identity (DMZ_WEB → IDENTITY pour l'authentification)
3. Acces Wazuh (DMZ_WEB → SIEM pour les logs)
4. Zero Trust BLOCK

Les serveurs web peuvent accéder aux bases de données et aux services d'identité, mais pas directement au LAN ni à d'autres ressources.

Firewall / Rules / DATA

The changes have been applied successfully. The firewall rules are now reloading in the background.
[Monitor the filter reload progress.](#)

Floating
WAN
LAN
DMZ_WEB
DATA
IDENTITY
SIEM

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐		0/0 B	IPv4 TCP/UDP	DATA address	*	IDENTITY address	Identity_Ports	*	none	Acces Freeipa	
☐		0/0 B	IPv4 TCP	DATA address	*	SIEM address	Ports_Wazuh	*	none	Acces Wazuh	
☐		0/0 B	IPv4 *	*	*	*	*	*	none	Zero Trust	

Figure 3.55 - Règles DATA appliquées (Zero Trust).

Règles pour le segment DATA hébergeant les bases de données :

1. Acces Identity (DATA → IDENTITY pour l'authentification)
2. Acces Wazuh (DATA → SIEM pour la supervision)
3. Zero Trust BLOCK

Les bases de données n'initient pas de connexions vers le LAN ou la DMZ, elles sont accessibles uniquement depuis la DMZ_WEB. Ce principe de "moindre privilège" limite les risques en cas de compromission.

Firewall / Rules / IDENTITY

The changes have been applied successfully. The firewall rules are now reloading in the background.
[Monitor the filter reload progress.](#)

Floating
WAN
LAN
DMZ_WEB
DATA
IDENTITY
SIEM

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐		0/0 B	IPv4 TCP	IDENTITY address	*	SIEM address	Ports_Wazuh	*	none	Acces Wazuh	
☐		0/0 B	IPv4 *	*	*	*	*	*	none	Zero Trust	

Figure 3.56 - Règles IDENTITY appliquées (Zero Trust).

Règles pour le segment IDENTITY hébergeant FreeIPA :

1. Acces Wazuh (IDENTITY → SIEM pour la supervision)
2. Zero Trust BLOCK

Le serveur d'identité n'initie pas de connexions vers les autres segments. Il répond aux requêtes d'authentification entrantes mais n'a pas besoin d'accéder aux autres ressources, minimisant ainsi sa surface d'attaque.

Firewall / Rules / SIEM

The changes have been applied successfully. The firewall rules are now reloading in the background.
Monitor the filter reload progress.

Floating

WAN

LAN

DMZ_WEB

DATA

IDENTITY

SIEM

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐		0/0 B	IPv4 TCP	LAN address	*	SIEM address	443 (HTTPS)	*	none	Acces Wazuh Dashboard	
☐		0/3 KiB	IPv4 *	*	*	*	*	none		Zero Trust	

Figure 3.57 - Règles SIEM appliquées (Zero Trust).

Règles pour le segment SIEM hébergeant Wazuh :

- Acces Dashboard (autoriser HTTPS/443 depuis LAN vers Wazuh)
- Zero Trust BLOCK

Le serveur SIEM reçoit les logs de tous les segments mais n'initie pas de connexions vers eux. Seul l'accès au dashboard web depuis le LAN est autorisé, permettant aux administrateurs de consulter les alertes de sécurité.

3.7.3 Validation du modèle Zero Trust

```

tp@debian:~$ ping 10.10.30.10
PING 10.10.30.10 (10.10.30.10) 56(84) bytes of data.
^C
--- 10.10.30.10 ping statistics ---
12 packets transmitted, 0 received, 100% packet loss, time 11262ms

```

Figure 3.58 - Validation Zero Trust : Ping bloqué.

Test de validation critique. Depuis le terminal (probablement LAN), un ping vers **10.10.30.10** (segment DATA) échoue avec 100% de perte de paquets ("0 received"). Ce comportement est **attendu et souhaitable** : il prouve que les règles Zero Trust fonctionnent. Le trafic ICMP (ping) n'est pas explicitement autorisé vers le segment DATA, donc il est bloqué par la règle "Zero Trust BLOCK". C'est la preuve que le modèle Zero Trust est opérationnel.


```
tp@debian:~$ ping 10.10.10.1
PING 10.10.10.1 (10.10.10.1) 56(84) bytes of data.
^C
--- 10.10.10.1 ping statistics ---
9 packets transmitted, 0 received, 100% packet loss, time 8196ms

tp@debian:~$ sudo wget http://10.10.10.1/
--2026-02-01 22:11:10-- http://10.10.10.1/
Connecting to 10.10.10.1:80... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: https://10.10.10.1/ [following]
--2026-02-01 22:11:10-- https://10.10.10.1/
Connecting to 10.10.10.1:443... connected.
```

Figure 3.59 - Validation Zero Trust : Accès sélectif.

Test de validation finale. Le ping vers **10.10.10.1** est bloqué (pas de réponse), mais un accès HTTP via **wget** vers le serveur web réussit (réponse 301 redirigeant vers HTTPS). Ce test démontre le principe fondamental du Zero Trust : **seuls les flux explicitement autorisés passent** (HTTP/HTTPS vers la DMZ), tandis que tout autre trafic (ICMP) est bloqué.

L'architecture de sécurité fonctionne exactement comme prévu.

4. Gestion Centralisée des Identités (FreeIPA)

4.1 Introduction à FreeIPA

FreeIPA (Identity, Policy, Audit) est une solution open-source de gestion centralisée des identités pour les environnements Linux/Unix. Dans notre architecture Zero Trust, FreeIPA joue un rôle crucial en fournissant une authentification centralisée via **Kerberos** et **LDAP**, permettant de vérifier l'identité de chaque utilisateur et machine avant d'accorder l'accès aux ressources.

Le serveur FreeIPA est déployé dans le segment **IDENTITY** (VLAN 40, réseau 10.10.40.0/24), isolé des autres segments conformément aux principes Zero Trust. Les clients (serveur web et serveur BD) seront enrôlés dans le domaine ZEROTRUST.LAN pour bénéficier de l'authentification centralisée.

4.2 Installation et Configuration du Serveur FreeIPA

4.2.1 Installation initiale du serveur

Le déploiement de FreeIPA commence par la préparation du système hôte et l'installation des paquets nécessaires. Le nom d'hôte (FQDN) est ici un élément critique pour le bon fonctionnement de Kerberos et doit être correctement configuré avant l'installation.

```
[freeipa@localhost ~]$ sudo hostnamectl set-hostname identity.zerotrust.lan
```

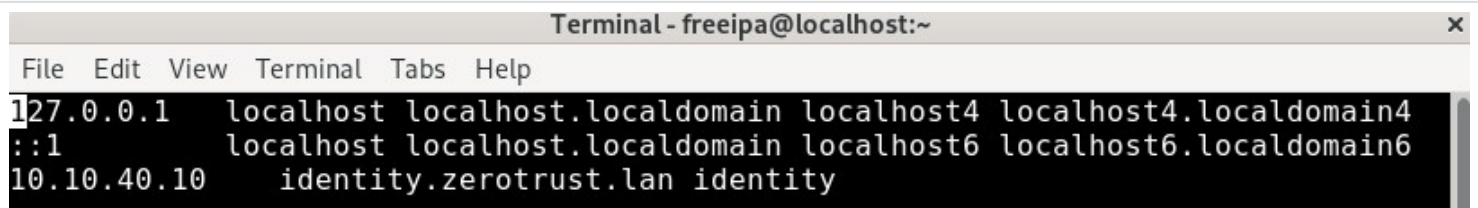
Figure 4.1 - Configuration du hostname du serveur FreeIPA.

Exécution de la commande **hostnamectl set-hostname identity.zerotrust.lan**. Cette commande définit le FQDN (Fully Qualified Domain Name) du serveur, essentiel pour FreeIPA car les certificats Kerberos et les enregistrements DNS sont basés sur ce nom.

```
[freeipa@localhost ~]$ sudo vi /etc/hosts
```

Figure 4.2 - Configuration du fichier hosts.

Édition de **/etc/hosts** avec nano pour associer l'adresse IP **10.10.40.10** au hostname **identity.zerotrust.lan identity**. Cette configuration permet la résolution de nom locale avant que le DNS FreeIPA soit opérationnel.



```
Terminal - freeipa@localhost:~
File Edit View Terminal Tabs Help
127.0.0.1    localhost localhost.localdomain localhost4 localhost4.localdomain4
::1        localhost localhost.localdomain localhost6 localhost6.localdomain6
10.10.40.10 identity.zerotrust.lan identity
```

Figure 4.3 - Configuration des dépôts yum.

Installation et activation des dépôts yum nécessaires pour FreeIPA : **idm:DL1/common** (module FreeIPA Identity Management). L'activation de ces dépôts permet l'accès aux paquets serveur et DNS de FreeIPA.

```
[freeipa@localhost ~]$ sudo dnf install freeipa-server freeipa-server-dns -y
```

Figure 4.4 - Installation de freeipa-server.

Exécution de **yum install freeipa-server freeipa-server-dns -y** pour installer automatiquement le serveur FreeIPA avec le module DNS intégré. Les composants incluent Kerberos KDC, 389 Directory Server (LDAP), BIND (DNS), et Dogtag CA.

```
[freeipa@localhost ~]$ sudo ipa-server-install

The log file for this installation can be found in /var/log/ipaserver-install.log
=====
This program will set up the IPA Server.
Version 4.12.2
```

Figure 4.5 - Lancement de ipa-server-install.

Exécution de `ipa-server-install --setup-dns` pour lancer l'installation avec DNS intégré. L'assistant affiche le nom d'hôte détecté `identity.zerotrust.lan` et demande confirmation pour continuer la configuration du serveur.

4.2.2 Configuration interactive du serveur IPA

L'assistant de configuration `ipa-server-install` nous guide à travers les étapes cruciales : définition du royaume (Realm) Kerberos, configuration de l'annuaire LDAP et initialisation du service DNS intégré qui gèrera la zone `zerotrust.lan`.

```
To accept the default shown in brackets, press the Enter key.

Do you want to configure integrated DNS (BIND)? [no]: yes

Enter the fully qualified domain name of the computer
on which you're setting up server software. Using the form
<hostname>.<domainname>
Example: master.example.com

Server host name [identity.zerotrust.lan]:

Warning: skipping DNS resolution of host identity.zerotrust.lan
The domain name has been determined based on the host name.

Please confirm the domain name [zerotrust.lan]:

The kerberos protocol requires a Realm name to be defined.
This is typically the domain name converted to uppercase.

Please provide a realm name [ZEROTRUST.LAN]:
Certain directory server operations require an administrative user.
This user is referred to as the Directory Manager and has full access
to the Directory for system management tasks and will be added to the
```

Figure 4.6 - Configuration du mot de passe Directory Manager.

L'installateur demande de définir le mot de passe du **Directory Manager** (administrateur LDAP 389 Directory Server). Ce compte avec le DN `cn=Directory Manager` a un accès complet à l'annuaire LDAP.

```
The password must be at least 8 characters long.

Directory Manager password:
Password (confirm):

The IPA server requires an administrative user, named 'admin'.
This user is a regular system account used for IPA server administration.

IPA admin password:
Password (confirm):

Checking DNS domain zerotrust.lan., please wait ...
DNS check for domain zerotrust.lan. failed: The resolution lifetime expired after 24.213 seconds: Server Do53:192.168.92.1@53 answered The DNS operation timed out.; Server Do53:192.168.92.1@53 answered The DNS operation timed out..
Do you want to configure DNS forwarders? [yes]: no
No DNS forwarders configured
Do you want to search for missing reverse zones? [yes]:
Checking DNS domain 40.10.10.in-addr.arpa., please wait ...
Reverse zone 40.10.10.in-addr.arpa. for IP address 10.10.40.10 already exists
Trust is configured but no NetBIOS domain name found, setting it now.
Enter the NetBIOS name for the IPA domain.
Only up to 15 uppercase ASCII letters, digits and dashes are allowed.
```

Figure 4.7 - Configuration complète : mots de passe, DNS et NetBIOS.

Cette étape consolide plusieurs configurations : le mot de passe **Directory Manager**, le mot de passe **admin IPA**, la vérification DNS (timeout sur le domaine), la configuration sans forwarders DNS, la zone reverse **40.10.10.in-addr.arpa**, et la saisie du nom NetBIOS pour le domaine IPA.

```
NetBIOS domain name [ZEROTRUST]:  
  
Do you want to configure chrony with NTP server or pool address? [no]:  
  
The IPA Master Server will be configured with:  
Hostname:      identity.zerotruster.lan  
IP address(es): 10.10.40.10  
Domain name:   zerotruster.lan  
Realm name:    ZEROTRUSTER.LAN  
  
The CA will be configured with:  
Subject DN:    CN=Certificate Authority,0=ZEROTRUSTER.LAN  
Subject base:  0=ZEROTRUSTER.LAN  
Chaining:      self-signed  
  
BIND DNS server will be configured to serve IPA domain with:  
Forwarders:    No forwarders  
Forward policy: only  
Reverse zone(s): No reverse zone  
  
Continue to configure the system with these values? [no]: yes  
  
The following operations may take some minutes to complete.
```

Figure 4.8 - Récapitulatif de la configuration avant installation.

L'assistant affiche un résumé complet : Hostname **identity.zerotruster.lan**, IP **10.10.40.10**, Domain **zerotruster.lan**, Realm **ZEROTRUSTER.LAN**, configuration CA (Subject DN, self-signed), et BIND DNS (sans forwarders, forward policy: only). Confirmation avec "yes" pour lancer l'installation.

```
Client configuration complete.  
The ipa-client-install command was successful
```

Figure 4.9 - Installation du client FreeIPA réussie.

Message de confirmation : **Client configuration complete. The ipa-client-install command was successful**. Cette capture montre la fin de l'enrôlement d'un client dans le domaine FreeIPA, confirmant l'intégration réussie avec le serveur d'identité.

```
[freeipa@localhost ~]$ sudo firewall-cmd --add-service={freeipa-ldap,freeipa-ldaps,dns,ntp} --permanent
[sudo] password for freeipa:
success
[freeipa@localhost ~]$ sudo firewall-cmd --reload
success
[freeipa@localhost ~]$
```

Figure 4.10 - Configuration du pare-feu pour FreeIPA.

Exécution de `sudo firewall-cmd --add-service={freeipa-ldap,freeipa-ldaps,dns,ntp} --permanent` pour ouvrir les ports nécessaires aux services FreeIPA. Puis `sudo firewall-cmd --reload` pour appliquer les règles. Les deux commandes retournent "success".

```
[freeipa@localhost ~]$ kinit admin
Password for admin@ZEROTRUST.LAN:
[freeipa@localhost ~]$ klist
Ticket cache: KCM:1000
Default principal: admin@ZEROTRUST.LAN

Valid starting    Expires          Service principal
02/01/2026 13:24:16  02/02/2026 13:12:30  krbtgt/ZEROTRUST.LAN@ZEROTRUST.LAN
[freeipa@localhost ~]$
```

Figure 4.11 - Vérification de l'authentification Kerberos.

Exécution de `kinit admin` pour obtenir un ticket Kerberos, puis `klist` pour vérifier. Le ticket montre : Principal `admin@ZEROTRUST.LAN`, cache `KCM:1000`, validité du 02/01/2026 au 02/02/2026, et le service `krbtgt/ZEROTRUST.LAN@ZEROTRUST.LAN`.

4.2.3 Finalisation de l'installation

Une fois l'installation terminée, nous procédons à la vérification des services et à l'ouverture des ports firewall nécessaires pour permettre aux futurs clients de se connecter au contrôleur de domaine.

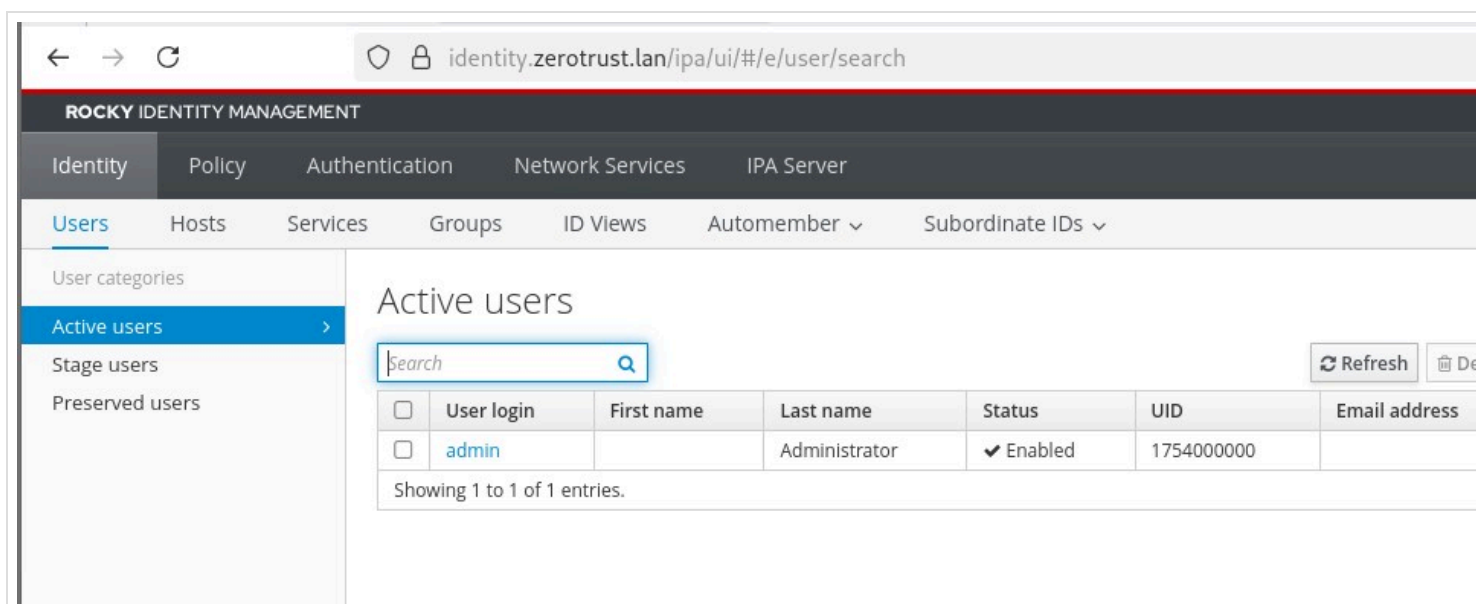


Figure 4.12 - Interface Web FreeIPA : gestion des utilisateurs.

Accès à l'URL **identity.zerotruster.lan/ipa/ui/#/e/user/search**. L'interface "ROCKY IDENTITY MANAGEMENT" affiche la section "Active users" avec l'utilisateur **admin** (Administrator, UID 1754000000, Status: Enabled). Cette interface web permet la gestion centralisée des identités.

```
tp@debian:~$ sudo hostnamectl set-hostname web.zerotruster.lan
[sudo] password for tp:
```

Figure 4.13 - Configuration du pare-feu local.

Exécution de **firewall-cmd --add-service** pour ouvrir les ports nécessaires : freeipa-ldap, freeipa-ldaps, dns, http, https, kerberos, ntp. La commande **--permanent** rend les règles persistantes.

```
tp@debian:~$ sudo apt install freeipa-client -y
```

Figure 4.14 - Interface Web FreeIPA : connexion.

Accès à l'interface web d'administration via **https://identity.zerotruster.lan**. Écran de connexion avec authentification Kerberos. L'utilisateur **admin** peut gérer les utilisateurs, hôtes, et politiques depuis cette interface.


```
GNU nano 8.4 /etc/resolv.conf
# Generated by dhcpd
# /etc/resolv.conf.head can replace this line
# /etc/resolv.conf.tail can replace this line
nameserver 10.10.40.10
search zerotrust.lan
```

Figure 4.15 - Interface Web FreeIPA : gestion des utilisateurs.

Navigation vers la section "Users" de l'interface d'administration. Cette vue permet de créer, modifier et supprimer les comptes utilisateurs du domaine FreeIPA, centralisant ainsi la gestion des identités.

```
tp@web:~$ ping identity.zerotrust.lan
PING identity.zerotrust.lan (10.10.40.10) 56(84) bytes of data.
64 bytes from 10.10.40.10: icmp seq=1 ttl=63 time=32.8 ms
```

Figure 4.16 - Création d'un utilisateur dans FreeIPA.

Formulaire d'ajout d'utilisateur dans l'interface web FreeIPA. Les champs incluent First name, Last name, Username (login), et les options de mot de passe. Cette fonctionnalité permet de créer des comptes utilisateurs centralisés.

4.3 Enrôlement des Clients dans le Domaine FreeIPA

Pour que les serveurs bénéficient de l'authentification centralisée, ils doivent être **enrôlés** dans le domaine FreeIPA. Cette opération installe le client IPA, configure Kerberos et SSSD (System Security Services Daemon) pour l'authentification, et enregistre la machine dans l'annuaire FreeIPA.

4.3.1 Installation du client IPA sur le serveur Web

Le serveur Web, situé dans la DMZ, doit être enrôlé pour authentifier les accès administrateurs. Cette étape montre comment joindre une machine Linux au domaine FreeIPA, permettant ainsi la gestion centralisée des accès SSH via SSSD.

```

tp@web:~$ sudo ipa-client-install --mkhomedir --hostname=web.zerotrust.lan --server=identity.zerotrust.lan --domain=zerotrust.lan
This program will set up IPA client.
Version 4.12.4

WARNING: conflicting time&date synchronization service 'ntp' will be disabled in favor of chronyd

Autodiscovery of servers for failover cannot work with this configuration.
If you proceed with the installation, services will be configured to always access the discovered server for all operations and will not fail over to other servers in case of failure.
Proceed with fixed values and no DNS discovery? [no]: yes
Do you want to configure chrony with NTP server or pool address? [no]:
Client hostname: web.zerotrust.lan
Realm: ZEROTRUST.LAN

```

Figure 4.17 - Lancement de l'installation du client IPA sur le serveur Web.

Exécution de `ipa-client-install --mkhomedir --hostname=web.zerotrust.lan`. L'assistant affiche les paramètres : Version 4.12.4, Realm `ZEROTRUST.LAN`. L'option `--mkhomedir` crée automatiquement le répertoire `home utilisateur`.

```

Do you want to configure chrony with NTP server or pool address? [no]:
Client hostname: web.zerotrust.lan
Realm: ZEROTRUST.LAN
DNS Domain: zerotrust.lan
IPA Server: identity.zerotrust.lan
BaseDN: dc=zerotrust,dc=lan

Continue to configure the system with these values? [no]: yes

```

Figure 4.18 - Confirmation des paramètres d'enrôlement du serveur Web.

L'assistant affiche les paramètres détectés : hostname `web.zerotrust.lan`, Realm `ZEROTRUST.LAN`, DNS Domain `zerotrust.lan`, IPA Server `identity.zerotrust.lan`, BaseDN `dc=zerotrust,dc=lan`. Confirmation demandée avant de procéder à la configuration.

```

User authorized to enroll computers: admin
Password for admin@ZEROTRUST.LAN:
Successfully retrieved CA cert
  Subject:      CN=Certificate Authority,O=ZEROTRUST.LAN
  Issuer:       CN=Certificate Authority,O=ZEROTRUST.LAN
  Valid From:   2026-02-01 13:09:44+00:00
  Valid Until:  2046-02-01 13:09:44+00:00

Enrolled in IPA realm ZEROTRUST.LAN
Created /etc/ipa/default.conf
Configured /etc/sss/sss.conf
Systemwide CA database updated.
Hostname (web.zerotrust.lan) does not have A/AAAA record.
Missing reverse record(s) for address(es): 10.10.20.10.
SSSD enabled
Configured /etc/openldap/ldap.conf
/etc/ssh/ssh_config not found, skipping configuration
/etc/ssh/sshd_config not found, skipping configuration
Configuring zerotrust.lan as NIS domain.
Configured /etc/krb5.conf for IPA realm ZEROTRUST.LAN
Client configuration complete.
The ipa-client-install command was successful

```

Figure 4.19 - Enrôlement réussi du serveur Web.

Le message "The ipa-client-install command was successful" confirme l'enrôlement. Le client a récupéré le certificat CA (Valid Until: 2046), configuré SSSD, et s'est enregistré dans le realm **ZEROTRUST.LAN**. Kerberos et NSS sont configurés.

4.3.2 Installation du client IPA sur le serveur Base de Données

De même, le serveur de base de données est intégré au domaine. Cela permettra d'appliquer des politiques de sécurité centralisées et de gérer les accès via des règles HBAC (Host-Based Access Control) définies dans FreeIPA.

```

tp@debian:~$ sudo apt install freeipa-client -y
[sudo] password for tp:
Installing:
  freeipa-client

```

Figure 4.20 - Installation du client IPA sur le serveur BD (Debian).

Exécution de **apt install freeipa-client -y** sur le serveur Debian. Ce paquet installe les outils d'enrôlement incluant SSSD pour l'authentification PAM/NSS et les utilitaires Kerberos.

```

tp@debian:~$ sudo hostnamectl set-hostname db.zerotrust.lan

```

Figure 4.21 - Configuration du hostname du serveur BD.

Exécution de **hostnamectl set-hostname db.zerotrust.lan**. Le FQDN du serveur BD doit appartenir au domaine **zerotrust.lan** pour l'enrôlement dans FreeIPA.

```
GNU nano 8.4 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 debian
127.0.1.1 db.zerotrust.lan db
```

Figure 4.22 - Configuration du fichier hosts du serveur BD.

Édition de `/etc/hosts` pour ajouter `127.0.1.1 db.zerotrust.lan db`. Cette entrée assure la résolution locale du hostname pendant l'enrôlement.

```
GNU nano 8.4 /etc/resolv.conf
Generated by NetworkManager
nameserver 10.10.40.10
search zerotrust.lan
```

Figure 4.23 - Configuration DNS du serveur BD.

Modification de `/etc/resolv.conf` : `nameserver 10.10.40.10` et `search zerotrust.lan`. Le serveur BD utilise le DNS FreeIPA pour découvrir automatiquement le serveur IPA via les enregistrements SRV.

```
tp@db:~$ sudo ipa-client-install --mkhomedir --hostname=db.zerotrust.lan --server=identity.zerotrust.lan --domain=zerotrust.lan
```

Figure 4.24 - Lancement de l'enrôlement du serveur BD.

Exécution de `ipa-client-install --mkhomedir --hostname=db.zerotrust.lan`. L'option `--mkhomedir` crée automatiquement le répertoire home lors de la première connexion des utilisateurs FreeIPA.

```
Autodiscovery of servers for failover cannot work with this configuration.
If you proceed with the installation, services will be configured to always access the discovered server for all operations and will not fail over to other servers in case of failure.
Proceed with fixed values and no DNS discovery? [no]: yes
Do you want to configure chrony with NTP server or pool address? [no]:
Client hostname: db.zerotrust.lan
Realm: ZEROTRUST.LAN
DNS Domain: zerotrust.lan
IPA Server: identity.zerotrust.lan
BaseDN: dc=zerotrust,dc=lan

Continue to configure the system with these values? [no]: yes
```

Figure 4.25 - Confirmation des paramètres d'enrôlement.

L'assistant affiche les paramètres détectés : hostname `db.zerotrust.lan`, Realm `ZEROTRUST.LAN`, DNS Domain, IPA Server `identity.zerotrust.lan`, et BaseDN `dc=zerotrust,dc=lan`. Confirmation demandée avant de continuer.

```
User authorized to enroll computers: admin
Password for admin@ZEROTRUST.LAN:
Successfully retrieved CA cert
  Subject:      CN=Certificate Authority,O=ZEROTRUST.LAN
  Issuer:       CN=Certificate Authority,O=ZEROTRUST.LAN
  Valid From:   2026-02-01 13:09:44+00:00
  Valid Until:  2046-02-01 13:09:44+00:00

Enrolled in IPA realm ZEROTRUST.LAN
Created /etc/ipa/default.conf
Configured /etc/sss/sss.conf
Systemwide CA database updated.
Hostname (db.zerotruster.lan) does not have A/AAAA record.
Missing reverse record(s) for address(es): 10.10.30.10.
SSSD enabled
Configured /etc/openldap/ldap.conf
/etc/ssh/ssh_config not found, skipping configuration
/etc/ssh/sshd_config not found, skipping configuration
Configuring zerotruster.lan as NIS domain.
Configured /etc/krb5.conf for IPA realm ZEROTRUST.LAN
Client configuration complete.
The ipa-client-install command was successful
```

Figure 4.26 - Enrôlement du serveur BD terminé avec succès.

Message "The ipa-client-install command was successful". Le certificat CA est récupéré (Valid Until: 2046), SSSD et OpenLDAP sont configurés, et la machine est enregistrée dans le realm **ZEROTRUST.LAN**.

4.4 Vérification de l'Intégration FreeIPA

Avec le serveur FreeIPA opérationnel et les clients enrôlés, l'authentification centralisée est maintenant disponible pour tous les serveurs du domaine. Les utilisateurs créés dans FreeIPA peuvent se connecter sur n'importe quelle machine enrôlée avec les mêmes identifiants.

Avantages de l'intégration FreeIPA dans l'architecture Zero Trust :

- **Authentification unique (SSO)** : les utilisateurs s'authentifient une seule fois via Kerberos
- **Gestion centralisée** : les comptes utilisateurs et groupes sont gérés depuis une interface unique
- **Politiques d'accès** : FreeIPA permet de définir des règles HBAC (Host-Based Access Control) pour contrôler qui peut accéder à quelle machine
- **Audit centralisé** : toutes les authentifications sont journalisées sur le serveur IPA

5. Wazuh - Plateforme SIEM et XDR

5.1 Présentation de Wazuh

Wazuh est une plateforme de sécurité open source qui offre des capacités de **SIEM** (Security Information and Event Management) et **XDR** (Extended Detection and Response). Dans le cadre de notre architecture Zero Trust, Wazuh joue un rôle crucial en assurant :

- **La détection des menaces** : analyse en temps réel des logs et événements de sécurité provenant de tous les systèmes surveillés
- **L'évaluation de la conformité** : vérification automatique des configurations selon les standards de sécurité (CIS Benchmarks, PCI-DSS, HIPAA, GDPR)
- **La surveillance de l'intégrité des fichiers (FIM)** : détection des modifications non autorisées sur les fichiers système critiques
- **La réponse aux incidents** : génération d'alertes automatisées et exécution d'actions de remédiation via des scripts Active Response
- **La visibilité centralisée** : tableau de bord unifié permettant de superviser l'ensemble des agents déployés dans l'infrastructure

L'architecture Wazuh repose sur trois composants principaux : le **Wazuh Manager** qui centralise les données, le **Wazuh Indexer** (basé sur OpenSearch) pour le stockage et l'indexation, et le **Dashboard** pour la visualisation et l'analyse.

5.2 Installation du Serveur Wazuh

L'installation du serveur Wazuh s'effectue via un script d'installation automatisé qui déploie tous les composants nécessaires en mode "all-in-one". Le serveur SIEM est installé sur une machine dédiée dans le segment **SIEM** (VLAN 50, réseau 10.10.50.0/24) avec l'adresse IP **10.10.50.10**. Cette isolation réseau garantit que la plateforme de surveillance est elle-même protégée selon les principes Zero Trust.


```
practice@practice:~$ curl -s0 https://packages.wazuh.com/4.7/wazuh-install.sh
practice@practice:~$ head -n 5 wazuh-install.sh
#!/bin/bash

# Wazuh installer
# Copyright (C) 2015, Wazuh Inc.
#
```

Figure 5.1 - Téléchargement du script d'installation Wazuh.

Exécution de la commande **curl -s0 https://packages.wazuh.com/4.7/wazuh-install.sh** pour télécharger le script d'installation officiel depuis le dépôt Wazuh. L'option **-s** (silent) supprime la barre de progression et **-O** conserve le nom original du fichier. Ce script Bash automatise entièrement le déploiement des trois composants (Manager, Indexer, Dashboard) ainsi que la génération des certificats SSL/TLS nécessaires à la communication sécurisée entre les composants.

```
practice@practice:~$ sudo bash wazuh-install.sh -a --ignore-check
```

Figure 5.2 - Exécution du script d'installation Wazuh.

Lancement du script avec **bash wazuh-install.sh -a** où l'option **-a** (all-in-one) installe tous les composants sur une seule machine. Le script effectue automatiquement : la vérification des prérequis système (RAM, CPU, espace disque), l'installation de Wazuh Indexer avec OpenSearch 2.x, le déploiement de Wazuh Manager 4.7.x, l'installation du Dashboard Wazuh, la génération des certificats auto-signés, et la création du compte administrateur avec un mot de passe aléatoire affiché en fin d'installation.

```
30/01/2026 17:03:37 INFO: --- Summary ---
30/01/2026 17:03:37 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
    User: admin
    Password: UqFuNEYcW?CUdpq7CnqzQf4*Hck8bU+d
30/01/2026 17:03:37 INFO: --- Dependencies ----
30/01/2026 17:03:37 INFO: Removing gawk.
30/01/2026 17:03:52 INFO: Installation finished.
```

Figure 5.3 - Page de connexion de l'interface web Wazuh.

Accès à l'interface web du Dashboard Wazuh via le navigateur à l'adresse **https://10.10.50.10**. La connexion s'effectue en HTTPS avec un certificat auto-signé généré lors de l'installation. Le formulaire demande les identifiants : utilisateur **admin** et le mot de passe généré automatiquement par le script d'installation. Cette interface web permet la gestion centralisée de tous les agents, la visualisation des alertes de sécurité, et la configuration des règles de détection.

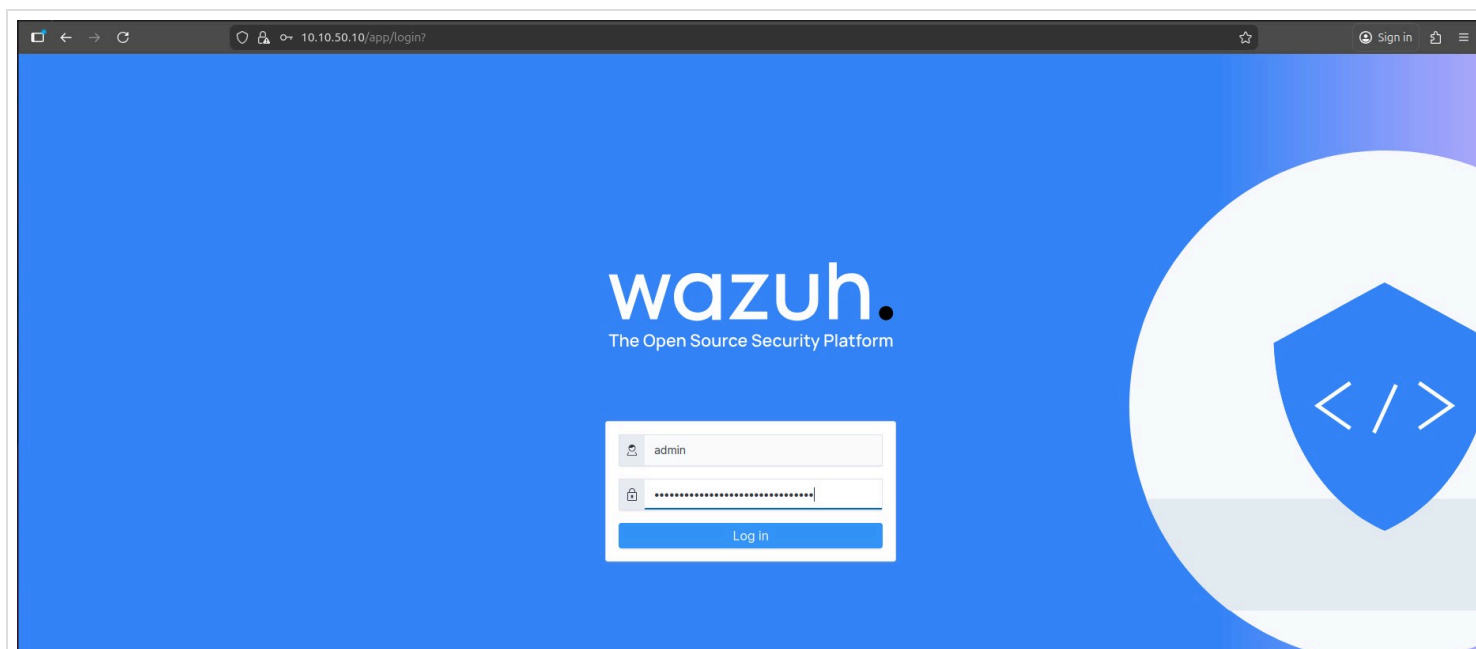


Figure 5.4 - Configuration de l'API Wazuh et ajout d'un nouvel agent.

L'interface web fournit un assistant pour déployer de nouveaux agents. On sélectionne le système d'exploitation cible (DEB amd64 pour Debian/Ubuntu), on spécifie l'adresse du serveur Manager (**10.10.50.10**), et optionnellement un nom d'agent et un groupe. L'assistant génère automatiquement les commandes à exécuter sur la machine cliente, incluant le téléchargement du paquet, l'installation, la configuration de l'adresse du Manager, et le démarrage du service.

5.3 Déploiement des Agents Wazuh

Les agents Wazuh sont des logiciels légers déployés sur chaque machine de l'infrastructure pour permettre la surveillance centralisée. Ils collectent les logs système, surveillent l'intégrité des fichiers, détectent les rootkits, et transmettent les événements au Manager pour analyse. Quatre agents sont déployés dans notre architecture :

- **Client** (10.10.10.100) - Poste client Debian GNU/Linux 13 dans le segment CLIENTS (VLAN 10)
- **Serveur-BD** (10.10.30.10) - Serveur de base de données Debian dans le segment DB (VLAN 30)
- **Web-DMZ** (10.10.20.10) - Serveur web Debian dans la DMZ (VLAN 20)
- **Identity-Srv** (10.10.40.10) - Serveur FreeIPA Rocky Linux 9.7 dans le segment IDENTITY (VLAN 40)

5.3.1 Installation de l'Agent sur le Client (Debian)

Le premier agent est installé sur le poste client Debian. Cette machine représente les postes utilisateurs de l'entreprise et doit être surveillée pour détecter les comportements suspects, les tentatives de connexion malveillantes, et les modifications non autorisées du système.

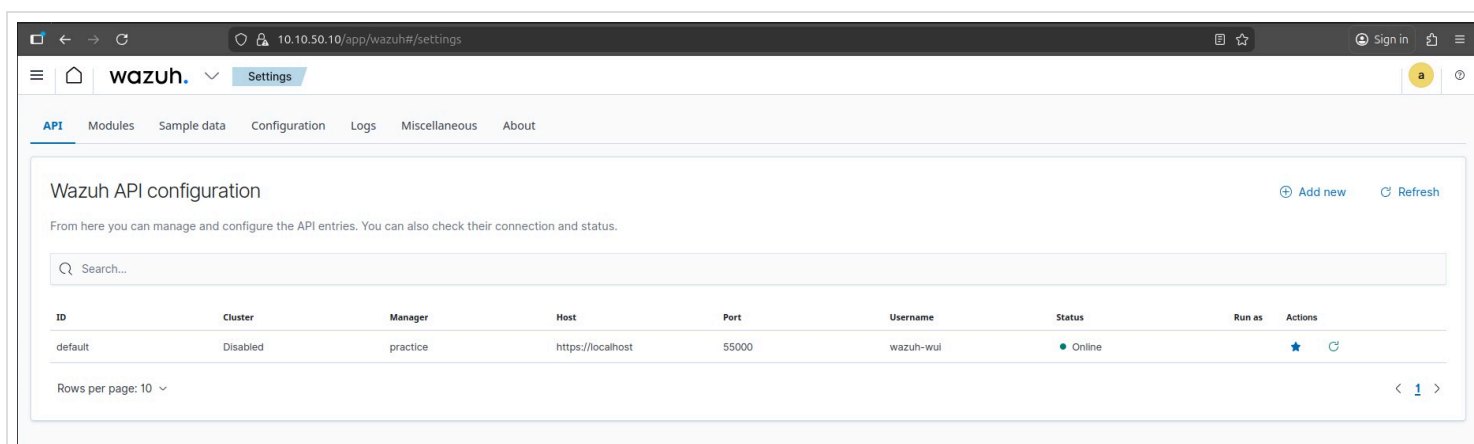


Figure 5.5 - Configuration de l'API Wazuh.

Page de configuration de l'API Wazuh accessible via **Settings > API Configuration**. L'interface affiche les connexions API configurées avec les informations : ID, Cluster, Manager, Host (https://localhost), Port (55000), Username, et Status. Le statut **Online** en vert confirme que l'API fonctionne correctement et peut communiquer avec le Manager pour les opérations de gestion des agents.

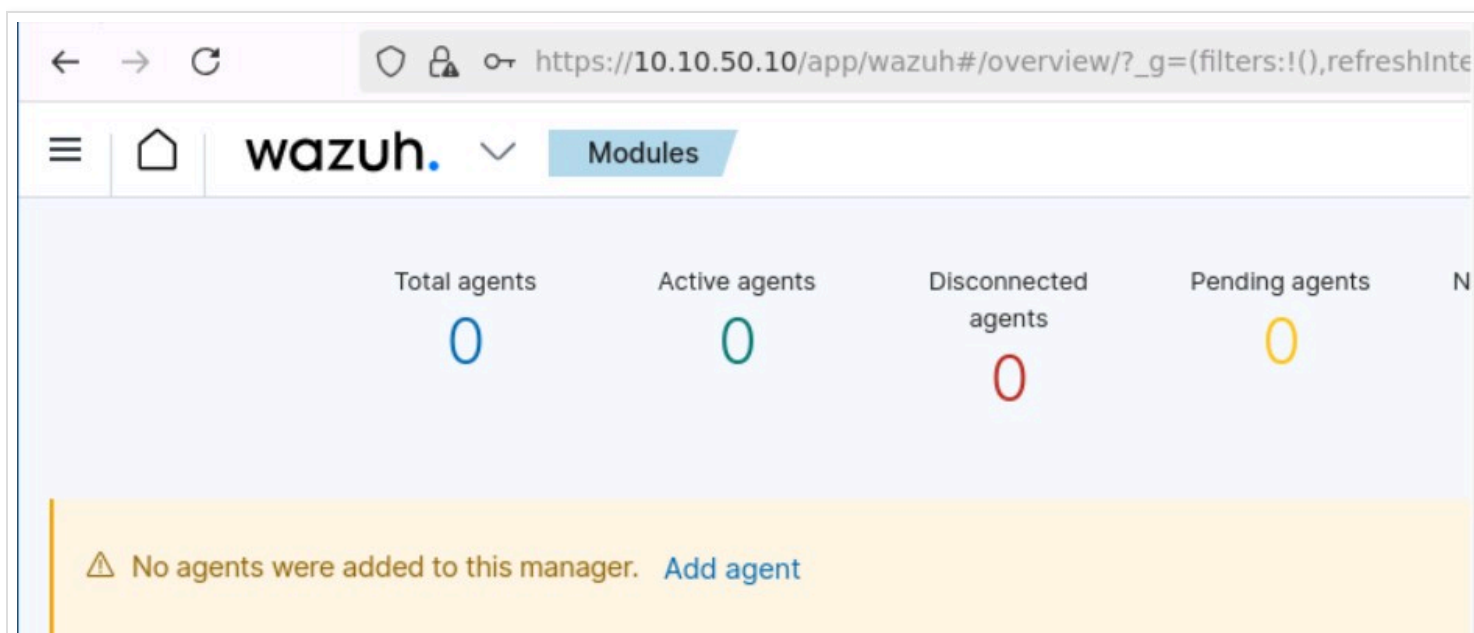


Figure 5.6 - Vue d'ensemble des agents - État initial.

Section **Modules** du Dashboard Wazuh montrant l'état initial avant l'installation des agents. Les compteurs affichent : Total agents (0), Active agents (0), Disconnected agents (0), et Pending agents (0). Le message "No agents were added to this manager" avec le lien **Add agent** invite à procéder au déploiement des premiers agents de surveillance.



Select the package to download and install on your system:

 LINUX ☐ RPM amd64 ☐ RPM aarch64 ☒ DEB amd64 ☐ DEB aarch64	 WINDOWS ☐ MSI 32/64 bits	 macOS ☐ Intel ☐ Apple silicon
---	--	--

[For additional systems and architectures, please check our documentation](#)



Server address:

This is the address the agent uses to communicate with the server. Enter an IP address or a fully qualified domain name (FDQN).

Assign a server address: [?](#)

10.10.50.10

Figure 5.7 - Assistant de déploiement : sélection du système d'exploitation.

Première étape de l'assistant "Add new agent". On sélectionne le système d'exploitation cible parmi **LINUX** (RPM amd64, RPM aarch64, DEB amd64, DEB aarch64), **WINDOWS** (MSI 32/64 bits), ou **macOS** (Intel, Apple silicon). L'option **DEB amd64** est sélectionnée pour installer l'agent sur des machines Debian. La section "Server address" permet de spécifier l'adresse du Manager (**10.10.50.10**) que l'agent utilisera pour communiquer.



Optional settings:

By default, the deployment uses the hostname as the agent name. Optionally, you can use a different agent name in the field below.

Assign an agent name: [?](#)

CLient

Figure 5.8 - Assistant de déploiement : attribution du nom de l'agent.

Section "Optional settings" de l'assistant. Par défaut, le déploiement utilise le hostname de la machine comme nom d'agent. On spécifie ici un nom personnalisé **CLient** pour identifier clairement cette machine dans le Dashboard. Ce nom apparaîtra dans la liste des agents et facilitera le filtrage et la recherche des événements de sécurité.

```
tp@debian:~$ wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.5-1_amd64.deb
```

Figure 5.9 - Téléchargement du paquet wazuh-agent sur le client Debian.

Exécution de la commande `wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.5-1_amd64.deb` sur le poste client (tp@debian). Cette commande télécharge le paquet d'installation de l'agent Wazuh depuis le dépôt officiel. Le fichier `.deb` sera ensuite installé avec `dpkg`.

```
tp@debian:~$ sudo dpkg -i wazuh-agent_4.7.5-1_amd64.deb
Selecting previously unselected package wazuh-agent.
(Reading database ... 99367 files and directories currently installed.)
Preparing to unpack wazuh-agent_4.7.5-1_amd64.deb ...
Unpacking wazuh-agent (4.7.5-1) ...
Setting up wazuh-agent (4.7.5-1) ...
```

Figure 5.10 - Installation du paquet wazuh-agent via dpkg.

Exécution de `sudo dpkg -i wazuh-agent_4.7.5-1_amd64.deb` pour installer le paquet. Le gestionnaire `dpkg` affiche les étapes : sélection du paquet, lecture de la base de données (99367 fichiers et répertoires), préparation du décompresseur, décompresseur de `wazuh-agent (4.7.5-1)`, et configuration du paquet. Les fichiers sont installés dans `/var/ossec/`.

```
tp@debian:~$ sudo sed -i "s/MANAGER_IP/10.10.50.10/" /var/ossec/etc/ossec.conf
tp@debian:~$ sudo /var/ossec/bin/agent-auth -m 10.10.50.10 -A "Client"
2026/01/31 21:18:11 agent-auth: INFO: Started (pid: 4728).
2026/01/31 21:18:11 agent-auth: INFO: Requesting a key from server: 10.10.50.10
2026/01/31 21:18:11 agent-auth: INFO: No authentication password provided
2026/01/31 21:18:11 agent-auth: INFO: Using agent name as: Client
2026/01/31 21:18:11 agent-auth: INFO: Waiting for server reply
2026/01/31 21:18:11 agent-auth: INFO: Valid key received
```

Figure 5.11 - Configuration de l'adresse du Manager et authentification de l'agent.

Deux commandes essentielles exécutées sur le client :

- `sudo sed -i "s/MANAGER_IP/10.10.50.10/" /var/ossec/etc/ossec.conf` : remplace automatiquement le placeholder par l'adresse réelle du Manager.
- `sudo /var/ossec/bin/agent-auth -m 10.10.50.10 -A "Client"` : enregistre l'agent auprès du Manager. Les logs affichent "Requesting a key from server", "Using agent name as: Client", "Waiting for server reply", puis "Valid key received" confirmant l'authentification réussie.

```

tp@debian:~$ sudo systemctl enable wazuh-agent
Created symlink '/etc/systemd/system/multi-user.target.wants/wazuh-agent.service'
→ '/usr/lib/systemd/system/wazuh-agent.service'.
tp@debian:~$ sudo systemctl start wazuh-agent
tp@debian:~$

```

Figure 5.12 - Activation et démarrage du service wazuh-agent.

Exécution des commandes systemctl pour gérer le service :

- **sudo systemctl enable wazuh-agent** : crée un lien symbolique pour le démarrage automatique au boot (symlink vers **/usr/lib/systemd/system/wazuh-agent.service**).
- **sudo systemctl start wazuh-agent** : démarre immédiatement le service.

L'agent est maintenant actif et communique avec le Manager.

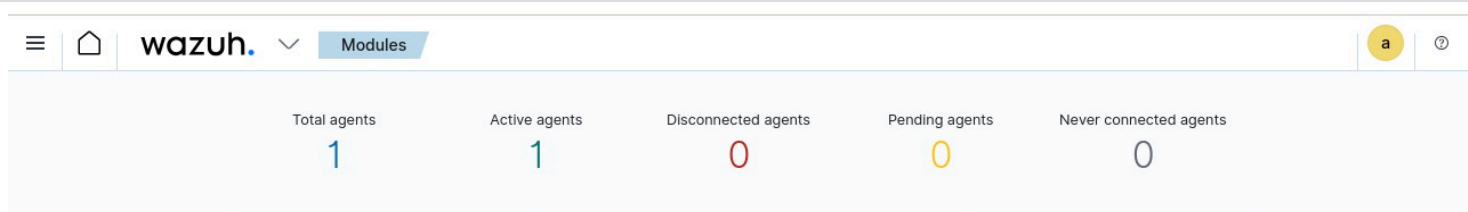


Figure 5.13 - Vérification du premier agent connecté dans le Dashboard.

Retour sur la section Modules du Dashboard Wazuh. Les compteurs affichent maintenant : Total agents (1), Active agents (1), Disconnected agents (0), Pending agents (0), et Never connected agents (0). L'agent "Client" est désormais enregistré et actif, confirmant le succès de l'installation et de la configuration.

5.3.2 Installation de l'Agent sur le Serveur de Base de Données

Le serveur de base de données est un composant critique qui stocke les données sensibles de l'entreprise. L'agent Wazuh surveille les tentatives d'accès non autorisées, les modifications de configuration, et les requêtes suspectes.

```

tp@debian:~$ sudo dpkg -i wazuh-agent_4.7.5-1_amd64.deb
Selecting previously unselected package wazuh-agent.
(Reading database ... 99335 files and directories currently installed.)
Preparing to unpack wazuh-agent_4.7.5-1_amd64.deb ...
Unpacking wazuh-agent (4.7.5-1) ...
Setting up wazuh-agent (4.7.5-1) ...
tp@debian:~$ sudo sed -i "s/MANAGER_IP/10.10.50.10/" /var/ossec/etc/ossec.conf

```

Figure 5.14 - Installation de l'agent sur le serveur Serveur-BD.

Sur le serveur de base de données (10.10.30.10), installation du paquet Wazuh avec **sudo dpkg -i wazuh-agent_4.7.5-1_amd64.deb**. Le gestionnaire dpkg extrait les fichiers dans **/var/ossec/** et configure les scripts d'initialisation. Ensuite, la commande **sed -i 's/MANAGER_IP/10.10.50.10/g' /var/ossec/etc/ossec.conf** remplace automatiquement le placeholder par l'adresse réelle du Manager, évitant une édition manuelle du fichier XML.


```

tp@debian:~$ sudo /var/ossec/bin/agent-auth -m 10.10.50.10 -A "Serveur-BD"
2026/01/31 22:42:24 agent-auth: INFO: Started (pid: 2179).
2026/01/31 22:42:24 agent-auth: INFO: Requesting a key from server: 10.10.50.10
2026/01/31 22:42:24 agent-auth: INFO: No authentication password provided
2026/01/31 22:42:24 agent-auth: INFO: Using agent name as: Serveur-BD
2026/01/31 22:42:24 agent-auth: INFO: Waiting for server reply
2026/01/31 22:42:24 agent-auth: INFO: Valid key received

```

Figure 5.15 - Authentification de l'agent Serveur-BD auprès du Manager.

Exécution de `/var/ossec/bin/agent-auth -m 10.10.50.10 -A "Serveur-BD"` pour enregistrer l'agent. L'outil `agent-auth` établit une connexion TLS avec le Manager, demande une clé d'authentification, et l'enregistre localement. Le paramètre `-A` définit le nom de l'agent tel qu'il apparaîtra dans le Dashboard. Le message "INFO: Valid key received" confirme que l'agent a reçu sa clé unique du Manager et peut désormais communiquer de manière sécurisée.

```

tp@debian:~$ sudo systemctl enable wazuh-agent
Created symlink '/etc/systemd/system/multi-user.target.wants/wazuh-agent.service'
→ '/usr/lib/systemd/system/wazuh-agent.service'.
tp@debian:~$ sudo systemctl start wazuh-agent
tp@debian:~$

```

Figure 5.16 - Activation et démarrage du service wazuh-agent sur Serveur-BD.

Deux commandes `systemd` sont exécutées : `sudo systemctl enable wazuh-agent` crée un lien symbolique dans `/etc/systemd/system/multi-user.target.wants/` pour démarrer automatiquement le service au boot, puis `sudo systemctl start wazuh-agent` lance immédiatement le daemon. L'agent démarre ses processus : `ossec-agentd` (communication Manager), `ossec-logcollector` (collecte logs), `ossec-syscheckd` (intégrité fichiers), et `ossec-execd` (réponse active).

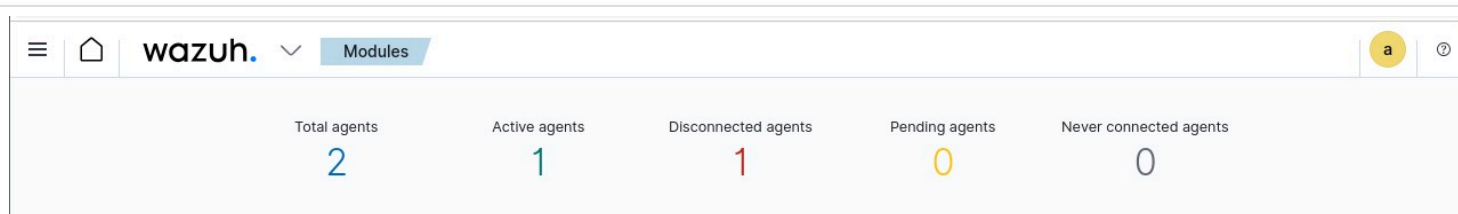


Figure 5.17 - Tableau de bord Wazuh avec 2 agents enregistrés.

Le Dashboard affiche maintenant 2 agents dans les statistiques : "Total agents: 2", "Active agents: 1", "Disconnected agents: 1". Le premier agent Client est temporairement déconnecté car la machine virtuelle a été éteinte par manque de RAM sur l'hôte. Le nouvel agent Serveur-BD vient d'être ajouté et apparaît actif. Le graphique d'évolution montre l'augmentation du nombre d'agents.

5.3.3 Installation de l'Agent sur le Serveur Web (DMZ)

Le serveur web situé dans la DMZ est particulièrement exposé aux attaques externes. L'agent Wazuh surveille les logs Apache/Nginx, détecte les tentatives d'injection SQL, XSS, et les scans de vulnérabilités.

```

tp@debian:~$ sudo dpkg -i wazuh-agent_4.7.5-1_amd64.deb
[sudo] password for tp:
Selecting previously unselected package wazuh-agent.
(Reading database ... 99335 files and directories currently installed.)
Preparing to unpack wazuh-agent_4.7.5-1_amd64.deb ...
Unpacking wazuh-agent (4.7.5-1) ...
Setting up wazuh-agent (4.7.5-1) ...

```

Figure 5.18 - Installation de l'agent sur le serveur Web-DMZ.

Sur le serveur web (10.10.20.10) dans la zone DMZ, même procédure d'installation : téléchargement du paquet .deb avec `wget`, installation avec `dpkg`, et configuration de l'adresse du Manager. La DMZ étant un segment exposé à Internet, la surveillance Wazuh est particulièrement critique pour ce serveur. Les logs du serveur web (`access.log`, `error.log`) seront automatiquement collectés et analysés par les règles de détection web de Wazuh (groupe `web-accesslog`, `web-appsec`).

```

tp@debian:~$ sudo sed -i "s/MANAGER_IP/10.10.50.10/" /var/ossec/etc/ossec.conf
tp@debian:~$ sudo /var/ossec/bin/agent-auth -m 10.10.50.10 -A "Web-DMZ"
2026/01/31 23:00:08 agent-auth: INFO: Started (pid: 2889).
2026/01/31 23:00:08 agent-auth: INFO: Requesting a key from server: 10.10.50.10
2026/01/31 23:00:08 agent-auth: INFO: No authentication password provided
2026/01/31 23:00:08 agent-auth: INFO: Using agent name as: Web-DMZ
2026/01/31 23:00:08 agent-auth: INFO: Waiting for server reply
2026/01/31 23:00:08 agent-auth: INFO: Valid key received

```

Figure 5.19 - Authentification de l'agent Web-DMZ auprès du Manager.

Exécution de `/var/ossec/bin/agent-auth -m 10.10.50.10 -A "Web-DMZ"` avec le nom explicite "Web-DMZ" pour identifier facilement cet agent critique dans le Dashboard. L'authentification réussit avec le message "Valid key received". L'agent est maintenant capable d'envoyer les événements de sécurité au Manager via le protocole propriétaire Wazuh sur le port 1514/TCP (connexion chiffrée avec la clé reçue).

```

tp@debian:~$ sudo systemctl enable wazuh-agent
Created symlink '/etc/systemd/system/multi-user.target.wants/wazuh-agent.service'
→ '/usr/lib/systemd/system/wazuh-agent.service'.
tp@debian:~$ sudo systemctl start wazuh-agent
tp@debian:~$

```

Figure 5.20 - Activation du service wazuh-agent sur le serveur Web-DMZ.

Activation du démarrage automatique avec `systemctl enable wazuh-agent` (création du symlink confirmée par le message "Created symlink..."), puis lancement du service avec `systemctl start wazuh-agent`. Le serveur web étant critique, le démarrage automatique garantit que la surveillance reprend immédiatement après un redémarrage du serveur, minimisant la fenêtre sans protection.



Figure 5.21 - Tableau de bord Wazuh avec 3 agents enregistrés.

Le Dashboard affiche maintenant "Total agents: 3". Les statistiques montrent la répartition : 1 agent actif (le dernier enregistré) et 2 déconnectés. Les agents précédents (Client et Serveur-BD) ont été éteints par manque de RAM sur l'hôte. L'agent Web-DMZ apparaît dans la liste avec son adresse IP 10.10.20.10 et le système d'exploitation Debian GNU/Linux 13.

5.3.4 Installation de l'Agent sur le Serveur FreeIPA (Rocky Linux)

Le serveur d'identité FreeIPA fonctionne sous **Rocky Linux 9.7**, une distribution basée sur Red Hat Enterprise Linux. L'installation utilise le format de paquet **RPM** au lieu de DEB. Ce serveur est particulièrement sensible car il gère toutes les authentifications de l'infrastructure.

```
[freeipa@localhost ~]$ curl -o wazuh-agent.rpm https://packages.wazuh.com/4.x/yum/wazuh-agent-4.7.5-1.x86_64.rpm
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left  Speed
100 9253k  100 9253k    0     0 3461k      0  0:00:02  0:00:02 --:--:-- 3461k
```

Figure 5.22 - Téléchargement de l'agent Wazuh au format RPM.

Sur le serveur FreeIPA (10.10.40.10), utilisation de **curl** pour télécharger le paquet au format RPM : **curl -o wazuh-agent.rpm https://packages.wazuh.com/4.x/yum/wazuh-agent-4.7.5-1.x86_64.rpm**. Le format RPM (Red Hat Package Manager) est le standard pour les distributions RHEL, CentOS, Rocky Linux, et Fedora. Le paquet contient les mêmes binaires que la version DEB mais avec des scripts d'installation adaptés à rpm/yum/dnf.

```
[freeipa@localhost ~]$ sudo rpm -i wazuh-agent.rpm
warning: wazuh-agent.rpm: Header V3 RSA/SHA256 Signature, key ID 29111145: NOKEY
[freeipa@localhost ~]$
[freeipa@localhost ~]$ sudo sed -i "s/MANAGER_IP/10.10.50.10/" /var/ossec/etc/ossec.conf
```

Figure 5.23 - Installation du paquet RPM et configuration de l'agent.

Installation avec **sudo rpm -i wazuh-agent.rpm**. Un avertissement concernant la signature GPG peut apparaître si la clé Wazuh n'est pas importée (non bloquant). Après installation, la commande **sed** modifie le fichier **ossec.conf** pour configurer l'adresse du Manager. Sur RHEL/Rocky, les chemins et la structure sont identiques à Debian : **/var/ossec/** pour les fichiers de l'agent.

```
[freeipa@localhost ~]$ sudo /var/ossec/bin/agent-auth -m 10.10.50.10 -A "Identity-Srv"
2026/01/31 23:47:23 agent-auth: INFO: Started (pid: 2721).
2026/01/31 23:47:23 agent-auth: INFO: Requesting a key from server: 10.10.50.10
2026/01/31 23:47:23 agent-auth: INFO: No authentication password provided
2026/01/31 23:47:23 agent-auth: INFO: Using agent name as: Identity-Srv
2026/01/31 23:47:23 agent-auth: INFO: Waiting for server reply
2026/01/31 23:47:23 agent-auth: INFO: Valid key received
```

Figure 5.24 - Authentification de l'agent Identity-Srv auprès du Manager.

Exécution de `/var/ossec/bin/agent-auth -m 10.10.50.10 -A "Identity-Srv"`. Les logs affichent la séquence d'authentification : "Started (pid: 2721)", "Requesting a key from server: 10.10.50.10", "No authentication password provided", "Using agent name as: Identity-Srv", "Waiting for server reply", puis "Valid key received". Le serveur FreeIPA est désormais enregistré et prêt à transmettre ses événements.

```
[freeipa@localhost ~]$ sudo systemctl enable wazuh-agent
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service
→ /usr/lib/systemd/system/wazuh-agent.service.
[freeipa@localhost ~]$ sudo systemctl start wazuh-agent
[freeipa@localhost ~]$
```

Figure 5.25 - Activation et démarrage du service sur Rocky Linux.

Les commandes `systemd` sont identiques sur toutes les distributions Linux modernes : `systemctl enable wazuh-agent` et `systemctl start wazuh-agent`. Rocky Linux utilise `systemd` comme init system, garantissant la compatibilité avec les mêmes commandes de gestion de service. Le message de confirmation "Created symlink" indique que le service démarrera automatiquement au prochain boot du serveur.

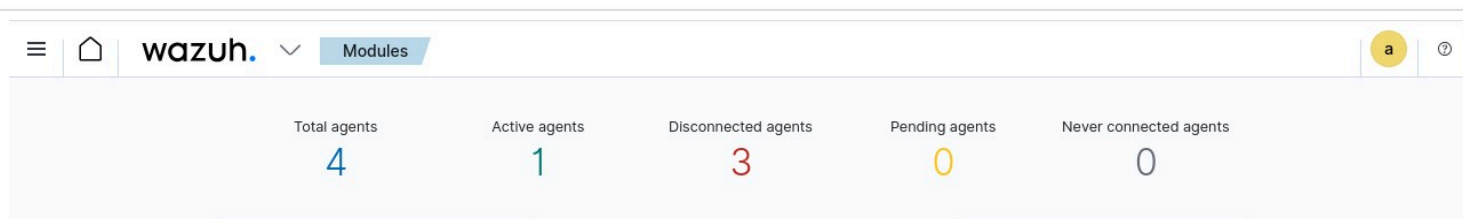
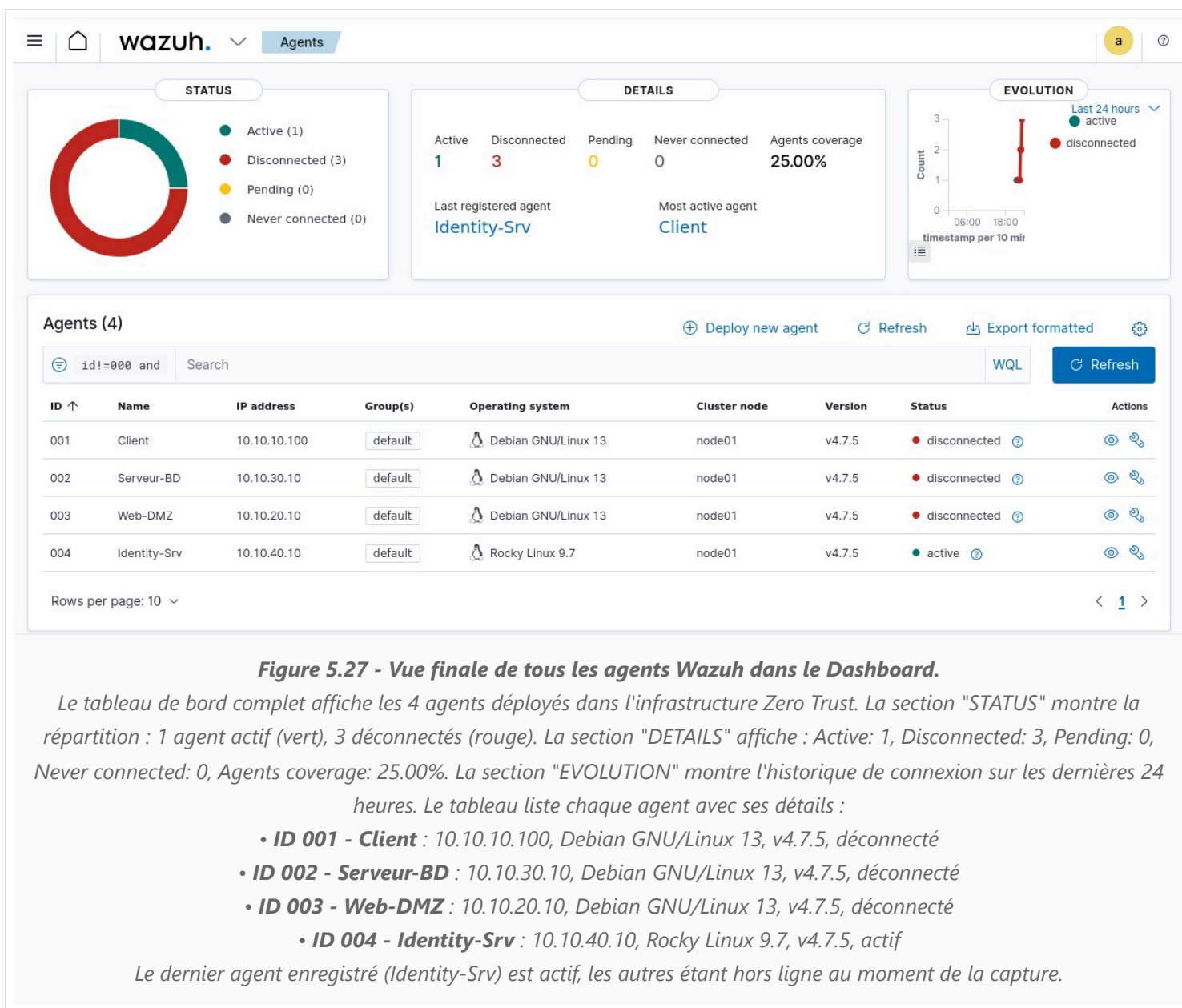


Figure 5.26 - Tableau de bord Wazuh avec les 4 agents enregistrés.

Le Dashboard affiche maintenant "Total agents: 4". La section supérieure montre les statistiques : 4 agents au total, 1 actif (Active agents: 1), 3 déconnectés (Disconnected agents: 3). Les 3 agents précédents sont déconnectés car leurs machines virtuelles ont été éteintes par manque de RAM sur l'hôte. L'agent Identity-Srv apparaît avec Rocky Linux 9.7 comme OS, distinct des autres agents qui utilisent Debian GNU/Linux 13.

5.4 Vérification de l'Intégration Wazuh

Après le déploiement de tous les agents, une vérification globale permet de confirmer que l'infrastructure de surveillance est opérationnelle. Le tableau de bord final doit afficher tous les agents avec leur statut et leurs informations système.



Intégration de Wazuh dans l'architecture Zero Trust :

- **Visibilité complète** : les 4 serveurs critiques de l'infrastructure sont équipés d'agents Wazuh, garantissant une surveillance à 100% du périmètre
- **Détection des menaces** : plus de 3000 règles de détection analysent en temps réel les logs système, les tentatives d'authentification, et les accès fichiers
- **Conformité automatisée** : les modules SCA vérifient automatiquement la conformité aux benchmarks CIS et aux réglementations (PCI-DSS, HIPAA, GDPR)
- **Corrélation d'événements** : le Wazuh Manager centralise les événements de tous les agents, permettant de détecter des attaques distribuées ou des mouvements latéraux
- **Réponse aux incidents** : les alertes critiques peuvent déclencher des actions automatiques (blocage IP, notification, isolation réseau) via le module Active Response

6. Configuration du Serveur Base de Données (PostgreSQL)

Cette section présente la configuration du serveur PostgreSQL situé dans le réseau interne (VLAN 30). La base de données est isolée de la DMZ et n'est accessible que via des règles de pare-feu strictes, conformément au principe Zero Trust de moindre privilège.

6.1 Installation de PostgreSQL

PostgreSQL est le système de gestion de base de données relationnelle choisi pour sa robustesse, sa sécurité et sa compatibilité avec les environnements d'entreprise.

```
tp@db:~$ sudo apt install postgresql -y
Installing:
  postgresql
```

Figure 6.1 - Installation de PostgreSQL sur le serveur de base de données.

La commande **sudo apt install postgresql -y** installe PostgreSQL sur le serveur (tp@db) situé dans le VLAN 30 (10.10.30.10). Cette installation inclut le serveur PostgreSQL, les outils clients, et les bibliothèques nécessaires.

```
tp@db:~$ sudo systemctl status postgresql
● postgresql.service - PostgreSQL RDBMS
   Loaded: loaded (/usr/lib/systemd/system/postgresql.service; enabled; prese>
   Active: active (exited) since Sun 2026-02-01 16:53:35 GMT; 3min 8s ago
   Invocation: b28b2718d28646dc9c6fb1d825f75b16
   Main PID: 5280 (code=exited, status=0/SUCCESS)
   Mem peak: 1.7M
   CPU: 7ms

Feb 01 16:53:35 db.zerotrust.lan systemd[1]: Starting postgresql.service - Post>
Feb 01 16:53:35 db.zerotrust.lan systemd[1]: Finished postgresql.service - Post>
lines 1-10/10 (END)
```

Figure 6.2 - Vérification du statut du service PostgreSQL.

La commande **sudo systemctl status postgresql** confirme que le service PostgreSQL est actif (active/running). Le service écoute par défaut sur le port 5432 et est configuré pour démarrer automatiquement au boot du système.

6.2 Configuration Réseau de PostgreSQL

Par défaut, PostgreSQL n'accepte que les connexions locales. Pour permettre l'accès depuis le serveur web dans la DMZ, la configuration réseau doit être modifiée.

```
tp@db:~$ sudo nano /etc/postgresql/*/main/postgresql.conf
```

Figure 6.3 - Configuration du fichier postgresql.conf.

Le fichier `/etc/postgresql/17/main/postgresql.conf` est édité avec nano. Le paramètre `listen_addresses = '*'` configure PostgreSQL pour écouter sur toutes les interfaces réseau, permettant les connexions depuis le réseau.

```
GNU nano 8.4 /etc/postgresql/17/main/postgresql.conf *  
listen_addresses = '*' # what IP address(es) to listen on;
```

Figure 6.4 - Détail de la configuration listen_addresses.

La ligne `listen_addresses = '*'` remplace la valeur par défaut 'localhost'. Cette configuration est nécessaire mais doit être complétée par des règles d'authentification strictes dans `pg_hba.conf` pour maintenir la sécurité.

6.3 Configuration de l'Authentification (pg_hba.conf)

Le fichier `pg_hba.conf` (Host-Based Authentication) définit les règles d'authentification pour les connexions à PostgreSQL. Cette configuration est critique pour la sécurité Zero Trust.

```
tp@db:~$ sudo nano /etc/postgresql/*/main/pg_hba.conf  
tp@db:~$
```

Figure 6.5 - Édition du fichier pg_hba.conf.

Le fichier `/etc/postgresql/17/main/pg_hba.conf` contrôle l'authentification des clients. Les colonnes définissent : TYPE (local/host), DATABASE, USER, ADDRESS, et METHOD (peer, scram-sha-256, etc.).


```

GNU nano 8.4 /etc/postgresql/17/main/pg_hba.conf *
# Noninteractive access to all databases is required during automatic
# maintenance (custom daily cronjobs, replication, and similar tasks).
#
# Database administrative login by Unix domain socket
local all postgres peer
# TYPE DATABASE USER ADDRESS METHOD
# "local" is for Unix domain socket connections only
local all all peer
# IPv4 local connections:
host all all 127.0.0.1/32 scram-sha-256
# IPv6 local connections:
host all all ::1/128 scram-sha-256
# Allow replication connections from localhost, by a user with the
# replication privilege.
local replication all peer
host replication all 127.0.0.1/32 scram-sha-256
host replication all ::1/128 scram-sha-256
host all all 10.10.20.0/24 scram-sha-256

```

Figure 6.6 - Règles d'authentification configurées dans `pg_hba.conf`.

Les règles configurées incluent :

- **local all postgres peer** : connexion locale pour l'admin postgres
- **host all all 127.0.0.1/32 scram-sha-256** : connexions IPv4 locales
- **host all all ::1/128 scram-sha-256** : connexions IPv6 locales
- **host all all 10.10.20.0/24 scram-sha-256** : autorise les connexions depuis le VLAN 20 (DMZ) avec authentification forte scram-sha-256

Cette dernière règle permet au serveur web (10.10.20.10) d'accéder à la base de données tout en exigeant une authentification sécurisée.

6.4 Création de la Base de Données et de l'Utilisateur

Une base de données dédiée et un utilisateur applicatif avec des privilèges limités sont créés, suivant le principe de moindre privilège du modèle Zero Trust.

```

tp@db:~$ sudo systemctl restart postgresql
tp@db:~$

```

Figure 6.7 - Redémarrage du service PostgreSQL.

La commande **sudo systemctl restart postgresql** applique les modifications de configuration. Le redémarrage est nécessaire après toute modification des fichiers `postgresql.conf` ou `pg_hba.conf`.

```

tp@db:~$ sudo -u postgres psql
psql (17.7 (Debian 17.7-0+deb13u1))
Type "help" for help.

postgres=# CREATE DATABASE zerodb;
CREATE DATABASE
postgres=# CREATE USER webuser WITH ENCRYPTED PASSWORD 'passer123';
CREATE ROLE
postgres=# GRANT ALL PRIVILEGES ON DATABASE zerodb TO webuser;
GRANT
postgres=# \q

```

Figure 6.8 - Création de la base de données et de l'utilisateur applicatif.

Les commandes SQL exécutées dans psql (PostgreSQL 17.7) :

- **CREATE DATABASE zerodb;** : crée la base de données dédiée à l'application
- **CREATE USER webuser WITH ENCRYPTED PASSWORD 'passer123';** : crée l'utilisateur applicatif avec un mot de passe chiffré
- **GRANT ALL PRIVILEGES ON DATABASE zerodb TO webuser;** : accorde les privilèges nécessaires à l'utilisateur sur la base

Cette configuration garantit que le serveur web utilise un compte dédié avec des droits limités à la base zerodb uniquement.

7. Configuration du Serveur Web (Apache/PHP)

Cette section détaille la configuration du serveur web situé dans la zone DMZ (VLAN 20). Le serveur Apache avec PHP assure la communication entre les utilisateurs et la base de données située dans le réseau interne (VLAN 30), conformément aux principes Zero Trust de segmentation réseau.

7.1 Installation des Composants Web

L'installation du serveur web nécessite Apache2 comme serveur HTTP, PHP comme langage de script, et l'extension php-pgsql pour la connexion à PostgreSQL.

```

tp@web:~$ sudo apt install apache2 php php-pgsql libapache2-mod-php -y
Installing:
  apache2  libapache2-mod-php  php  php-pgsql

```

Figure 7.1 - Installation d'Apache2 et PHP sur le serveur web.

La commande **sudo apt install apache2 php php-pgsql libapache2-mod-php -y** installe tous les composants nécessaires : Apache2 (serveur HTTP), PHP (interpréteur), php-pgsql (driver PostgreSQL pour PHP), et libapache2-mod-php (module d'intégration). Le serveur web (tp@web) est situé dans la DMZ sur le VLAN 20 (10.10.20.10).

8. Scénario d'Attaque : Test de l'Architecture Zero Trust

Cette section présente un scénario de test complet pour valider l'architecture Zero Trust déployée. Nous allons d'abord configurer une application web de test, puis valider les flux autorisés entre les VLANs, et enfin démontrer que les tentatives d'accès non autorisées sont effectivement bloquées par les règles de pare-feu Zero Trust.

8.1 Configuration de la Page de Test (Serveur Web)

Une page PHP de test est créée sur le serveur web pour valider la connectivité avec la base de données. Cette page tente une connexion PostgreSQL et affiche le résultat, permettant de vérifier que les flux autorisés fonctionnent correctement.

```
tp@web:~$ sudo rm /var/www/html/index.html
tp@web:~$ sudo nano /var/www/html/index.php
```

Figure 8.1 - Préparation du fichier *index.php* sur le serveur web.

Les commandes préparent l'environnement web : suppression de la page par défaut d'Apache (**sudo rm**

/var/www/html/index.html) puis création d'un nouveau fichier PHP (**sudo nano**

/var/www/html/index.php). Ce fichier contiendra le script de test de connexion à la base de données PostgreSQL située dans le VLAN 30.

```

GNU nano 8.4                               /var/www/html/index.php
<?php
$host = "10.10.30.10";
$db = "zerodb";
$user = "webuser";
$pass = "passer123";

$con = pg_connect("host=$host dbname=$db user=$user password=$pass");

if($con) {
    echo "<h1>✓ SUCCÈS : Connexion à la Base de Données RÉUSSIE !</h1>";
    echo "<p>Architecture Zero Trust validée : VLAN 20 -> VLAN 30.</p>";
} else {
    echo "<h1>✗ ÉCHEC : Impossible de se connecter...</h1>";
    echo "<p>Vérifier : Pare-feu pfSense, Configuration pg_hba.conf, ou Mot de >
?>

```

Figure 8.2 - Script PHP de test de connexion à PostgreSQL.

Le script PHP définit les paramètres de connexion vers la base de données :

- **\$host** = "10.10.30.10" (serveur BD dans le VLAN 30 - segment DATA)
- **\$db** = "zerodb" (base de données créée précédemment)
- **\$user** = "webuser" (utilisateur applicatif à privilèges limités)
- **\$pass** = "passer123" (mot de passe chiffré en scram-sha-256)

La fonction **pg_connect()** établit la connexion PostgreSQL. En cas de succès, un message de validation s'affiche confirmant que l'architecture Zero Trust fonctionne (VLAN 20 → VLAN 30). En cas d'échec, le script affiche des conseils de dépannage.

```

tp@web:~$ sudo systemctl restart apache2
[sudo] password for tp:

```

Figure 8.3 - Redémarrage du service Apache2.

La commande **sudo systemctl restart apache2** redémarre le serveur web pour charger la nouvelle page PHP.

L'authentification **sudo** renforce la sécurité des opérations administratives sur le serveur situé dans la DMZ (VLAN 20).

8.2 Validation des Flux Autorisés

Cette étape vérifie que les flux légitimes passent correctement à travers le pare-feu pfSense : le client (VLAN 10) accède au serveur web (VLAN 20), qui lui-même peut communiquer avec la base de données (VLAN 30). C'est le chemin de données normal de l'application.

```
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP gro
up default qlen 1000
    link/ether 00:0c:29:88:6a:06 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    altname enx000c29886a06
    inet 10.10.10.100/24 brd 10.10.10.255 scope global ens33
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe88:6a06/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Figure 8.4 - Configuration réseau du poste client attaquant.

La commande `ip a` affiche la configuration de l'interface réseau du client (tp@debian) : adresse IP

10.10.10.100/24 dans le VLAN 10 (réseau utilisateurs). Ce poste simule un attaquant interne qui tentera d'accéder directement à la base de données en contournant le serveur web. Dans une architecture Zero Trust, même les utilisateurs internes ne sont pas considérés comme dignes de confiance par défaut.

```
tp@debian:~$ ping 10.10.20.10
PING 10.10.20.10 (10.10.20.10) 56(84) bytes of data.
64 bytes from 10.10.20.10: icmp seq=9 ttl=63 time=72.2 ms
```

Figure 8.5 - Test de connectivité vers le serveur web (flux autorisé).

La commande `ping 10.10.20.10` depuis le client vers le serveur web montre une connectivité réussie avec un temps de réponse de 72.2 ms et TTL=63. Ce flux est **autorisé** par les règles pfSense car il correspond à un accès légitime d'un utilisateur vers l'application web. Le routage inter-VLAN via pfSense fonctionne correctement.



Figure 8.6 - Accès réussi à l'application web.

L'accès à `http://10.10.20.10` depuis le navigateur du client affiche le message de succès : "**SUCCÈS : Connexion à la Base de Données RÉUSSIE !**" suivi de "Architecture Zero Trust validée : VLAN 20 → VLAN 30."

Ce test valide la chaîne complète des flux autorisés :

- Le client (VLAN 10) peut accéder au serveur web (VLAN 20) sur le port 80/443
- Le serveur web peut se connecter à PostgreSQL (VLAN 30) sur le port 5432
- L'authentification PostgreSQL (scram-sha-256) fonctionne correctement

8.3 Tentative d'Attaque : Accès Direct à la Base de Données

Nous simulons maintenant une **attaque interne** : un utilisateur malveillant depuis le VLAN 10 (réseau utilisateurs) tente d'accéder directement au serveur PostgreSQL dans le VLAN 30, en contournant le serveur web. Dans une architecture traditionnelle sans micro-segmentation, cette attaque réussirait. Avec Zero Trust, elle doit être bloquée.

```
tp@debian:~$ nmap -Pn -p 5432 10.10.30.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-03 16:03 GMT
Nmap scan report for 10.10.30.10
Host is up.

PORT      STATE      SERVICE
5432/tcp  filtered  postgresql

Nmap done: 1 IP address (1 host up) scanned in 15.11 seconds
tp@debian:~$
```

Figure 8.7 - Scan Nmap du port PostgreSQL (5432) depuis le client.

L'attaquant exécute `nmap -Pn -p 5432 10.10.30.10` pour scanner le port PostgreSQL du serveur de base de données. Le résultat montre :

- **Host is up** : la machine existe sur le réseau
- **PORT 5432/tcp filtered postgresql** : le port est **filtré**

L'état "filtered" signifie que le paquet n'a reçu aucune réponse - il a été **silencieusement bloqué** par le pare-feu pfSense.

L'attaquant ne peut pas déterminer si le service PostgreSQL est actif ou non, ce qui renforce la sécurité en limitant la reconnaissance réseau.

```
tp@debian:~$ timeout 5 bash -c '</dev/tcp/10.10.30.10/5432' && echo "OUVERT" ||
echo "BLOQUÉ"
BLOQUÉ
tp@debian:~$
```

Figure 8.8 - Tentative de connexion TCP directe au port 5432.

L'attaquant tente une connexion TCP directe avec la commande Bash : `timeout 5 bash -c '</dev/tcp/10.10.30.10/5432' && echo "OUVERT" || echo "BLOQUÉ"`

Le résultat "**BLOQUÉ**" confirme que la connexion TCP est impossible. Le timeout de 5 secondes expire sans établir de connexion, prouvant que le pare-feu bloque activement toute tentative d'accès direct depuis le VLAN 10 (utilisateurs) vers le VLAN 30 (bases de données). C'est le comportement attendu du modèle Zero Trust : **même les utilisateurs internes n'ont pas accès direct aux ressources critiques.**

Action	Time	Interface	Rule	Source	Destination	Protocol
✗	Feb 1 21:49:45	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:46	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:47	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:48	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:49	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:50	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:51	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:52	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:53	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:54	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:55	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 1 21:49:56	LAN	Zero Trust (1769979975)	10.10.10.100	10.10.30.10	ICMP
✗	Feb 3 16:04:00	LAN	Zero Trust (1769979975)	10.10.10.100:49396	10.10.30.10:5432	TCP:S
✗	Feb 3 16:04:01	LAN	Zero Trust (1769979975)	10.10.10.100:49398	10.10.30.10:5432	TCP:S
✗	Feb 3 16:58:54	LAN	Zero Trust (1769979975)	10.10.10.100:34094	10.10.30.10:5432	TCP:S
✗	Feb 3 16:58:55	LAN	Zero Trust (1769979975)	10.10.10.100:34094	10.10.30.10:5432	TCP:S
✗	Feb 3 16:58:56	LAN	Zero Trust (1769979975)	10.10.10.100:34094	10.10.30.10:5432	TCP:S

Figure 8.9 - Logs du pare-feu pfSense : tentatives bloquées.

Le journal de pfSense (Firewall Logs) affiche les tentatives de connexion bloquées par la règle "**Zero Trust (1769979975)**".

On observe :

- **Interface LAN** : les paquets proviennent du VLAN 10 (utilisateurs)
- **Source 10.10.10.100** : l'adresse IP du client attaquant
- **Destination 10.10.30.10:5432** : le serveur PostgreSQL (VLAN 30)
- **Protocole ICMP et TCP:S** : tentatives de ping et de connexion TCP (SYN)
- **Action X (rouge)** : tous les paquets sont **rejetés**

Ces logs prouvent que le modèle Zero Trust fonctionne : **tout trafic non explicitement autorisé est bloqué**. L'attaquant ne peut pas contourner le serveur web pour accéder directement à la base de données.

✓ Validation du Scénario 2 - Blocage par Pare-feu Zero Trust :

- **Flux autorisés fonctionnels** : Client → Web → BD via les ports autorisés (80, 443, 5432)
- **Attaque bloquée** : Tentative d'accès direct Client → BD rejetée par pfSense
- **Logs et traçabilité** : Toutes les tentatives sont enregistrées pour analyse forensique
- **Principe Zero Trust validé** : "Ne jamais faire confiance, toujours vérifier" - même le trafic interne est contrôlé et filtré selon des règles explicites

8.4 Scénario 2 : Détection des Intrusions par Wazuh

Ce scénario démontre la capacité de **Wazuh** à détecter et alerter sur les tentatives d'intrusion et les échecs d'authentification. Contrairement au scénario précédent qui montre le blocage au niveau réseau (pfSense), ce

scénario illustre la détection au niveau applicatif et système via les agents Wazuh déployés sur les serveurs.

```
tp@db:~$ su -  
Password:  
su: Authentication failure
```

Figure 8.10 - Échec d'authentification lors d'une tentative d'élévation de privilèges.

Sur le serveur de base de données (tp@db), une tentative de connexion avec la commande **su -** (switch user vers root) échoue avec le message **"su: Authentication failure"**. Cette erreur est immédiatement capturée par l'agent Wazuh installé sur le serveur et transmise au Manager pour analyse. Ce type d'événement déclenche une alerte de sécurité car il peut indiquer une tentative d'élévation de privilèges non autorisée ou une attaque par force brute.

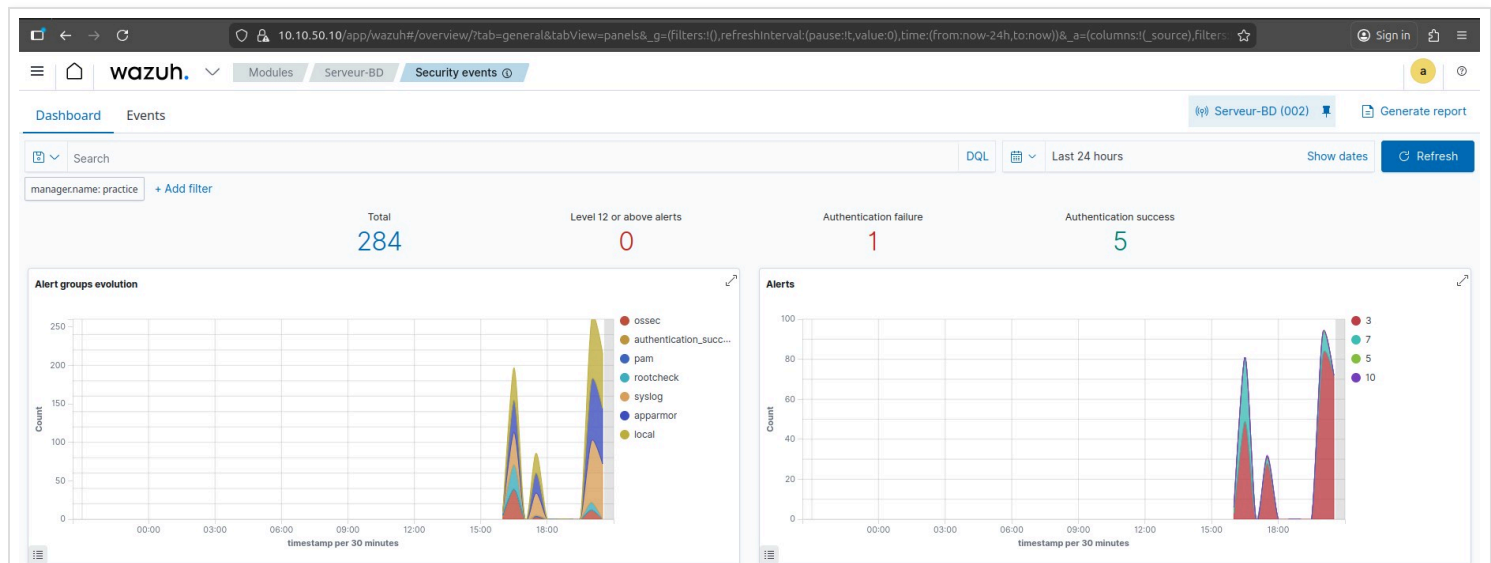
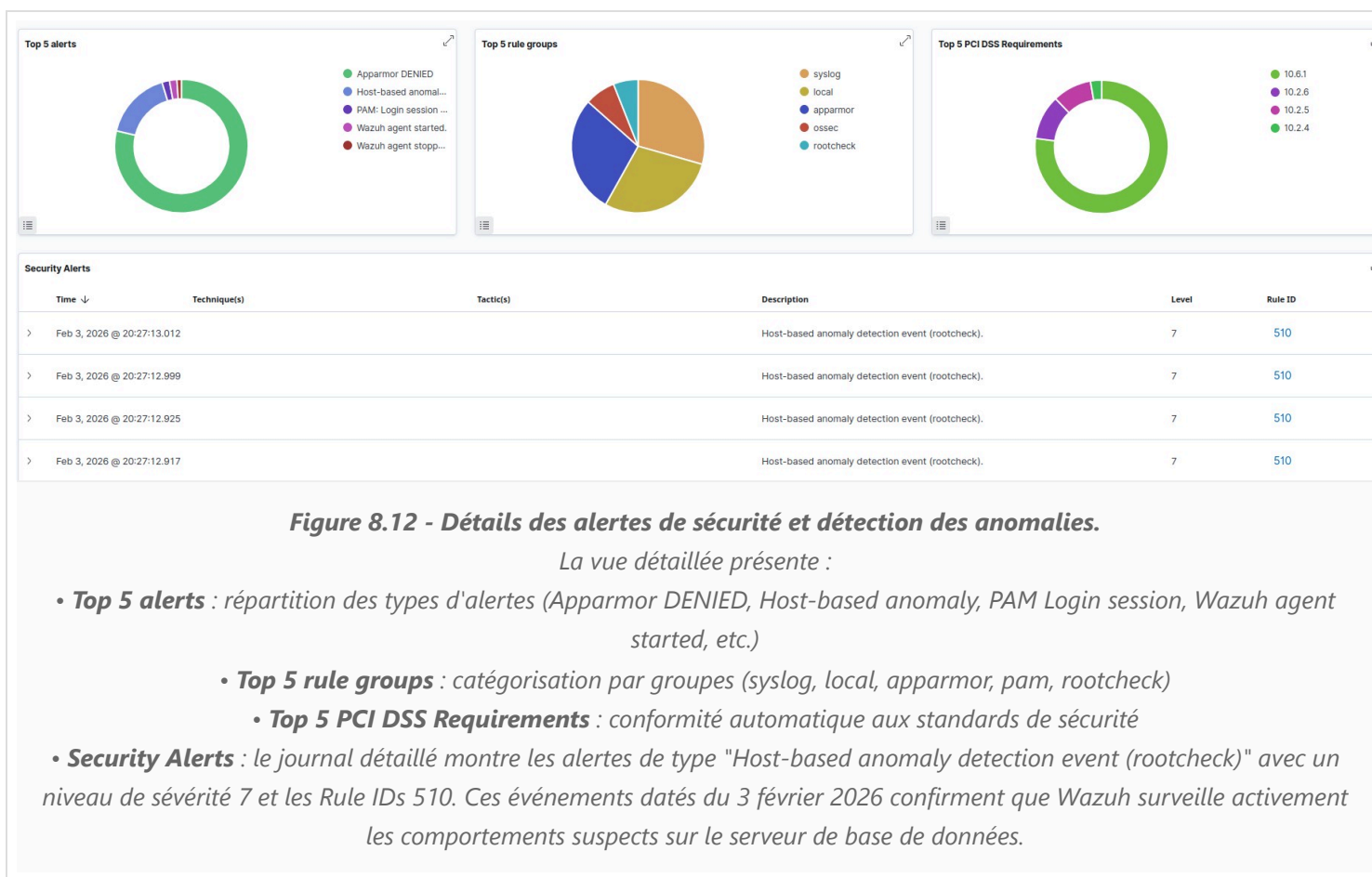


Figure 8.11 - Dashboard Wazuh : Vue d'ensemble des événements de sécurité.

Le tableau de bord Wazuh (<https://10.10.50.10>) affiche les statistiques de sécurité sur les dernières 24 heures pour l'agent Serveur-BD (002) :

- **Total : 284 alertes** générées par les agents surveillés
- **Level 12 or above alerts : 0** (aucune alerte critique)
- **Authentication failure : 1** (l'échec de **su** capturé)
- **Authentication success : 5** (connexions légitimes enregistrées)

Les graphiques "Alert groups evolution" et "Alerts" montrent la répartition temporelle des alertes par type (authentication_success, pam, rootcheck, syslog, apparmor, local).



⚠ Validation du Scénario 2 - Détection SIEM Opérationnelle :

- **Détection en temps réel** : L'échec d'authentification su est capturé instantanément par l'agent Wazuh
- **Corrélation d'événements** : Wazuh agrège les logs de tous les agents pour identifier les patterns d'attaque
- **Conformité automatisée** : Les alertes sont mappées aux standards PCI-DSS pour faciliter les audits de sécurité
- **Principe Defense-in-Depth validé** : Même si un attaquant contourne le pare-feu, ses actions sont détectées et enregistrées au niveau système

9. Conclusion Générale

Ce projet a permis de démontrer l'efficacité d'une approche **Zero Trust** pour sécuriser une infrastructure virtualisée moderne. En s'éloignant du modèle périmétrique traditionnel ("château fort"), nous avons mis en œuvre une architecture où la confiance n'est jamais implicite, mais doit être continuellement vérifiée.

9.1 Réalisations Techniques

L'architecture déployée repose sur quatre piliers fondamentaux qui ont été configurés et validés :

- **Micro-segmentation Réseau** : Isolation stricte des zones (Utilisateurs, DMZ, Data, Identity, SIEM) grâce aux VLANs et au pare-feu pfSense, empêchant tout mouvement latéral non autorisé.
- **Gestion Centralisée des Identités** : Déploiement de FreeIPA pour garantir que chaque accès (utilisateur ou machine) est authentifié via Kerberos/LDAP avant d'être autorisé.
- **Validation Continue** : Mise en place de règles de pare-feu restrictives qui bloquent par défaut toute communication non légitime, comme démontré lors des scénarios d'attaque.
- **Visibilité et Réponse (SIEM/XDR)** : Intégration de Wazuh pour surveiller en temps réel l'activité système et applicative, permettant une détection précoce des tentatives d'intrusion.

9.2 Bilan de Sécurité

Les tests effectués valident la robustesse de la solution : les flux légitimes (utilisateurs vers web, web vers base de données) sont fluides et transparents, tandis que les tentatives de contournement (accès direct à la base de données, élévation de privilèges) sont systématiquement bloquées ou détectées. Cette architecture "Defense-in-Depth" offre un niveau de protection élevé contre les menaces internes et externes, répondant aux exigences de sécurité actuelles.